Windows Security Band 2: Hardening

Windows-Netzwerke mit Active Directory professionell härten

Von Gruppenrichtlinien und Active Directory über Kerberos und Sysmon bis zum Server-Hardening.
Mit 38 Laborübungen im AD-Labor, Kontrollfragen und Lernzielkontrollen je Kapitel.

Inhaltsverzeichnis

Vorwort 9

Die Laborumgebung dieses Bandes 9

DC01 und die Domäne nova.int einrichten 9

Aufbau dieses Bandes 10

Kapitel 1: Windows Security Hardening 11

1. Einführung 11

2. Technische Grundlagen 11

3. Fachbegriffe 11

4. Praxis und Konfiguration 11

5. Sicherheitsbetrachtung 11

6. Praktische Laborübungen 12

7. Typische Fehler 12

8. Zusammenfassung 12

9. Kontrollfragen 13

10. Lernzielkontrolle 13

Kapitel 2: Windows Security Baselines 14

1. Einführung 14

2. Technische Grundlagen 14

3. Fachbegriffe 14

4. Praxis und Konfiguration 14

5. Sicherheitsbetrachtung 14

6. Praktische Laborübungen 15

7. Typische Fehler 15

8. Zusammenfassung 15

9. Kontrollfragen 15

10. Lernzielkontrolle 16

Kapitel 3: PowerShell für Security Administration 17

1. Einführung 17

2. Technische Grundlagen 17

3. Fachbegriffe 17

4. Praxis und Konfiguration 17

5. Sicherheitsbetrachtung 18

6. Praktische Laborübungen . . . 18
7. Typische Fehler . . . 18
8. Zusammenfassung . . . 18
9. Kontrollfragen . . . 19
10. Lernzielkontrolle . . . 19

Kapitel 4: Gruppenrichtlinien (GPO) . . . 20

1. Einführung . . . 20
2. Technische Grundlagen . . . 20
3. Fachbegriffe . . . 20
4. Praxis und Konfiguration . . . 20
5. Sicherheitsbetrachtung . . . 21
6. Praktische Laborübungen . . . 21
7. Typische Fehler . . . 22
8. Zusammenfassung . . . 22
9. Kontrollfragen . . . 22
10. Lernzielkontrolle . . . 22

Kapitel 5: Active Directory Security . . . 23

1. Einführung . . . 23
2. Technische Grundlagen . . . 23
3. Fachbegriffe . . . 23
4. Praxis und Konfiguration . . . 23
5. Sicherheitsbetrachtung . . . 23
6. Praktische Laborübungen . . . 24
7. Typische Fehler . . . 24
8. Zusammenfassung . . . 24
9. Kontrollfragen . . . 25
10. Lernzielkontrolle . . . 25

Kapitel 6: Benutzer- und Gruppenverwaltung . . . 26

1. Einführung . . . 26
2. Technische Grundlagen . . . 26
3. Fachbegriffe . . . 26
4. Praxis und Konfiguration . . . 26
5. Sicherheitsbetrachtung . . . 27
6. Praktische Laborübungen . . . 27
7. Typische Fehler . . . 27

8. Zusammenfassung . . . 27
9. Kontrollfragen . . . 28
10. Lernzielkontrolle . . . 28

Kapitel 7: Kerberos und NTLM . . . 29

1. Einführung . . . 29
2. Technische Grundlagen . . . 29
3. Fachbegriffe . . . 29
4. Praxis und Konfiguration . . . 29
5. Sicherheitsbetrachtung . . . 30
6. Praktische Laborübungen . . . 30
7. Typische Fehler . . . 30
8. Zusammenfassung . . . 30
9. Kontrollfragen . . . 31
10. Lernzielkontrolle . . . 31

Kapitel 8: SMB-Sicherheit . . . 32

1. Einführung . . . 32
2. Technische Grundlagen . . . 32
3. Fachbegriffe . . . 32
4. Praxis und Konfiguration . . . 32
5. Sicherheitsbetrachtung . . . 33
6. Praktische Laborübungen . . . 33
7. Typische Fehler . . . 33
8. Zusammenfassung . . . 33
9. Kontrollfragen . . . 34
10. Lernzielkontrolle . . . 34

Kapitel 9: Windows Defender Firewall im Unternehmen . . . 35

1. Einführung . . . 35
2. Technische Grundlagen . . . 35
3. Fachbegriffe . . . 35
4. Praxis und Konfiguration . . . 35
5. Sicherheitsbetrachtung . . . 35
6. Praktische Laborübungen . . . 36
7. Typische Fehler . . . 36
8. Zusammenfassung . . . 36
9. Kontrollfragen . . . 37

10. Lernzielkontrolle . . . 37

Kapitel 10: Microsoft Defender und Endpoint Protection . . . 38

1. Einführung . . . 38
2. Technische Grundlagen . . . 38
3. Fachbegriffe . . . 38
4. Praxis und Konfiguration . . . 38
5. Sicherheitsbetrachtung . . . 39
6. Praktische Laborübungen . . . 39
7. Typische Fehler . . . 39
8. Zusammenfassung . . . 39
9. Kontrollfragen . . . 40
10. Lernzielkontrolle . . . 40

Kapitel 11: BitLocker und Gerätesicherheit . . . 41

1. Einführung . . . 41
2. Technische Grundlagen . . . 41
3. Fachbegriffe . . . 41
4. Praxis und Konfiguration . . . 41
5. Sicherheitsbetrachtung . . . 41
6. Praktische Laborübungen . . . 42
7. Typische Fehler . . . 42
8. Zusammenfassung . . . 42
9. Kontrollfragen . . . 43
10. Lernzielkontrolle . . . 43

Kapitel 12: Windows-Dienste und Prozesssicherheit . . . 44

1. Einführung . . . 44
2. Technische Grundlagen . . . 44
3. Fachbegriffe . . . 44
4. Praxis und Konfiguration . . . 44
5. Sicherheitsbetrachtung . . . 44
6. Praktische Laborübungen . . . 45
7. Typische Fehler . . . 45
8. Zusammenfassung . . . 45
9. Kontrollfragen . . . 46
10. Lernzielkontrolle . . . 46

Kapitel 13: AppLocker und Windows Defender Application Control . . . 47

1. Einführung . . . 47
2. Technische Grundlagen . . . 47
3. Fachbegriffe . . . 47
4. Praxis und Konfiguration . . . 47
5. Sicherheitsbetrachtung . . . 47
6. Praktische Laborübungen . . . 48
7. Typische Fehler . . . 48
8. Zusammenfassung . . . 48
9. Kontrollfragen . . . 49
10. Lernzielkontrolle . . . 49

Kapitel 14: Windows Event Logging . . . 50

1. Einführung . . . 50
2. Technische Grundlagen . . . 50
3. Fachbegriffe . . . 50
4. Praxis und Konfiguration . . . 50
5. Sicherheitsbetrachtung . . . 51
6. Praktische Laborübungen . . . 51
7. Typische Fehler . . . 51
8. Zusammenfassung . . . 51
9. Kontrollfragen . . . 52
10. Lernzielkontrolle . . . 52

Kapitel 15: Sicherheitsüberwachung mit Sysmon . . . 53

1. Einführung . . . 53
2. Technische Grundlagen . . . 53
3. Fachbegriffe . . . 53
4. Praxis und Konfiguration . . . 53
5. Sicherheitsbetrachtung . . . 53
6. Praktische Laborübungen . . . 54
7. Typische Fehler . . . 54
8. Zusammenfassung . . . 54
9. Kontrollfragen . . . 55
10. Lernzielkontrolle . . . 55

Kapitel 16: Windows Server Hardening . . . 56

1. Einführung . . . 56
2. Technische Grundlagen . . . 56

3. Fachbegriffe . . . 56
4. Praxis und Konfiguration . . . 56
5. Sicherheitsbetrachtung . . . 56
6. Praktische Laborübungen . . . 57
7. Typische Fehler . . . 57
8. Zusammenfassung . . . 57
9. Kontrollfragen . . . 57
10. Lernzielkontrolle . . . 58

Kapitel 17: Remote Administration und RDP-Sicherheit . . . 59

1. Einführung . . . 59
2. Technische Grundlagen . . . 59
3. Fachbegriffe . . . 59
4. Praxis und Konfiguration . . . 59
5. Sicherheitsbetrachtung . . . 59
6. Praktische Laborübungen . . . 60
7. Typische Fehler . . . 60
8. Zusammenfassung . . . 60
9. Kontrollfragen . . . 61
10. Lernzielkontrolle . . . 61

Kapitel 18: Backup- und Wiederherstellungskonzepte . . . 62

1. Einführung . . . 62
2. Technische Grundlagen . . . 62
3. Fachbegriffe . . . 62
4. Praxis und Konfiguration . . . 62
5. Sicherheitsbetrachtung . . . 63
6. Praktische Laborübungen . . . 63
7. Typische Fehler . . . 63
8. Zusammenfassung . . . 63
9. Kontrollfragen . . . 64
10. Lernzielkontrolle . . . 64

Kapitel 19: Sicherheitskonzepte für Unternehmensnetzwerke . . . 65

1. Einführung . . . 65
2. Technische Grundlagen . . . 65
3. Fachbegriffe . . . 65
4. Praxis und Konfiguration . . . 65

5. Sicherheitsbetrachtung 66
6. Praktische Laborübungen 66
7. Typische Fehler 66
8. Zusammenfassung 66
9. Kontrollfragen 67
10. Lernzielkontrolle 67
Abschlussprojekt Band 2: Sicheres Unternehmensnetzwerk 67

Verzeichnis der Befehlsbeispiele 69

Index 71

Vorwort

Band 1 hat einen einzelnen, abgesicherten Windows-11-Client aufgebaut. Band 2 wechselt den Maßstab: vom Einzelgerät zum Unternehmensnetzwerk mit Active Directory. Die Mechanismen aus Band 1 (Benutzerkonten, NTFS-Rechte, Defender, Firewall, BitLocker) gelten weiterhin, werden hier aber zentral über Gruppenrichtlinien statt lokal pro Gerät verwaltet.

Dieses Buch setzt Band 1 als bekannt voraus. Begriffe wie UAC, SID, NTFS-Vererbung oder der Unterschied zwischen Echtzeitschutz und On-Demand-Scan werden hier nicht erneut erklärt.

Die Laborumgebung dieses Bandes

Band 2 erweitert das Labor aus Band 1 um die Domäneninfrastruktur aus dem Master-Prompt:

System	Rolle	Betriebssystem
CLIENT01	Arbeitsplatzrechner aus Band 1, jetzt Domänenmitglied	Windows 11 Pro
DC01	Active Directory Domain Controller, neu in diesem Band	Windows Server 2022
SRV01	Mitgliedsserver, neu in diesem Band	Windows Server 2022

CLIENT02 und KALI01 kommen erst in Band 3 hinzu, sobald plattformübergreifende Angriffsszenarien eine Rolle spielen.

Beispiel V.1: Erweiterte Netzwerkarchitektur

```
DC01       192.168.56.10   (Windows Server 2022, Domain Controller)
SRV01      192.168.56.20   (Windows Server 2022, Mitgliedsserver)
CLIENT01   192.168.56.50   (Windows 11 Pro, jetzt Domänenmitglied)
Domäne:    nova.int
Alle drei Systeme im selben, isolierten virtuellen Netzwerk.
```

> **WARNUNG – Sicherheitsrisiko**
>
> Jede Konfigurationsänderung in diesem Buch gehört ausschließlich in dieses isolierte Labor. Lege vor den Kapiteln zu GPO (4), Kerberos (7) und Server-Hardening (16) jeweils einen Prüfpunkt an.

DC01 und die Domäne nova.int einrichten

Beispiel V.2: Active Directory Domain Services installieren

```
PS> Install-WindowsFeature -Name AD-Domain-Services -IncludeManagementTools
PS> Install-ADDSForest -DomainName "nova.int" -InstallDns
```

Beispiel V.3: SRV01 und CLIENT01 der Domäne beitreten lassen

```
PS> Add-Computer -DomainName "nova.int" -Credential (Get-Credential) -Restart
```

> **Gut zu wissen**

> Der Server, der zum Domain Controller wird, startet nach `Install-ADDSForest` automatisch neu. Richte DNS vor dem Domänenbeitritt der übrigen Systeme so ein, dass sie DC01 als DNS-Server verwenden, da Active Directory auf funktionierender Namensauflösung aufbaut.

Aufbau dieses Bandes

Neunzehn Kapitel, gegliedert in vier Abschnitte: Grundlagen der Unternehmenshärtung (1-3), Active-Directory-Sicherheit (4-8), Endpunkt- und Serverschutz (9-17), sowie Betrieb und Gesamtkonzept (18-19).

Kapitel 1: Windows Security Hardening

Lernziele

- Du erklärst, was Hardening systematisch von einer Einzelmaßnahme unterscheidet.
- Du nutzt einen anerkannten Hardening-Standard (CIS Benchmark für Windows) als Orientierung.
- Du legst eine eigene, nachvollziehbare Hardening-Dokumentation an.

1. Einführung

Band 1 hat einzelne Maßnahmen eingeführt: ein Konto hier, eine Firewall-Regel dort. **Hardening** bündelt diese zu einem systematischen, wiederholbaren Prozess – und wird unter Windows durch zentrale Werkzeuge wie Gruppenrichtlinien (Kapitel 4) besonders wirksam, weil eine Änderung sofort für viele Systeme gleichzeitig gilt.

2. Technische Grundlagen

Das **CIS Benchmark für Windows** gliedert Hunderte Einzelprüfungen in Abschnitte wie Kontorichtlinien, lokale Richtlinien, Windows Defender Firewall und administrative Vorlagen, jeweils mit Level-1- (breit anwendbar) und Level-2-Empfehlungen (tiefergehend, funktionsrelevanter).

Beispiel 1.1: Der Hardening-Kreislauf (Konzept)

```
Baseline erfassen -> gegen Standard prüfen -> Abweichungen beheben
     -> zentral über GPO verteilen -> erneut prüfen (wiederkehrend)
```

3. Fachbegriffe

Eine **Baseline** ist der dokumentierte Ausgangszustand eines Systems. **Microsoft Security Baselines** sind von Microsoft selbst veröffentlichte, als GPO-Vorlagen vorliegende Empfehlungen, die sich direkt in Active Directory importieren lassen (vertieft in Kapitel 2). **Defense in Depth** verteilt Sicherheit auf mehrere, unabhängige Schichten.

4. Praxis und Konfiguration

Beispiel 1.2: Eine einfache Baseline-Dokumentation beginnen

```
PS> Get-LocalGroupMember -Group "Administratoren" > baseline_admins.txt
PS> Get-NetFirewallRule -Enabled True > baseline_firewall.txt
PS> Get-HotFix > baseline_updates.txt
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Nicht jede Benchmark-Empfehlung passt auf jede Umgebung. Level-2-Empfehlungen können Funktionalität einschränken, wenn sie unreflektiert auf alle Systeme einer Domäne verteilt werden. Teste jede GPO-Vorlage zunächst in einer separaten Testorganisationseinheit (Kapitel 4), bevor sie unternehmensweit greift.

6. Praktische Laborübungen

Übung A: Eine Baseline für DC01, SRV01 und CLIENT01 erstellen

Aufgabenstellung: Erstelle für alle drei Systeme eine dokumentierte Baseline nach Beispiel 1.2. **Ausgangssituation:** Labor nach Vorwort eingerichtet. **Voraussetzungen:** administrative PowerShell-Sitzungen auf allen drei Systemen. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 1.2, auf jedem System einzeln. **Erwartetes Ergebnis:** Drei Dateisätze, jeweils für ein System. **Überprüfung:** Jede Datei enthält plausible, nicht leere Inhalte. **Fehleranalyse:** Leere Firewall-Liste? Prüfen, ob die Firewall auf dem jeweiligen System tatsächlich aktiv ist. **Musterlösung:** Drei vollständige Baseline-Dokumentationen als Referenzpunkt für die folgenden Kapitel.

Übung B: Eine CIS-Empfehlung manuell gegen DC01 prüfen

Aufgabenstellung: Wähle zwei CIS-Windows-Server-Empfehlungen und prüfe DC01 manuell dagegen. **Ausgangssituation:** wie Übung A. **Voraussetzungen:** Internetzugang von einem anderen Gerät für die Benchmark-Dokumentation. **Schritt-für-Schritt-Anleitung:** Benchmark sichten, zwei Prüfpunkte wählen, jeweiligen Status auf DC01 ermitteln. **Erwartetes Ergebnis:** Für beide Prüfpunkte eine klare, begründete Aussage. **Überprüfung:** Begründung bezieht sich konkret auf DC01, nicht allgemein. **Fehleranalyse:** Unklarer Prüfpunkt? Zusätzliche Erläuterung im Benchmark-Dokument konsultieren. **Musterlösung:** Zwei vollständige, dokumentierte Prüfpunkte mit Bewertung.

7. Typische Fehler

Fehler	Ursache	Behebung
Hardening-Vorlage direkt unternehmensweit verteilt	kein Testlauf vorgeschaltet	immer zuerst in Testorganisationseinheit prüfen
Baseline nur für CLIENT01 erstellt	Server übersehen	alle drei Systeme gleichwertig dokumentieren
Level-2-Empfehlungen ungeprüft übernommen	Zeitdruck	Funktionsrisiko vorab abschätzen

8. Zusammenfassung

Zusammenfassung

- Hardening ist ein wiederkehrender Prozess, unter Windows durch zentrale GPO-Verteilung besonders wirksam.
- Das CIS Benchmark für Windows gliedert Empfehlungen in Level 1 und Level 2.
- Microsoft Security Baselines liegen direkt als importierbare GPO-Vorlagen vor.
- Jede neue Vorlage sollte zuerst in einer Testorganisationseinheit geprüft werden.

9. Kontrollfragen

1. Was ist eine Baseline? (leicht)
2. Was sind Microsoft Security Baselines? (leicht)
3. Warum ist zentrale GPO-Verteilung für Hardening besonders wirksam? (mittel)
4. Was unterscheidet Level-1- von Level-2-Empfehlungen? (mittel)
5. Ein Administrator möchte eine neue Hardening-Vorlage sofort auf alle Domänenmitglieder anwenden. Welches konkrete Risiko siehst du, und wie würdest du vorgehen? (schwer)

Lösungshinweise: 1. Der dokumentierte Ausgangszustand eines Systems. 2. Von Microsoft veröffentlichte, als GPO-Vorlagen vorliegende Hardening-Empfehlungen. 3. Weil eine einzelne Änderung sofort für alle betroffenen Systeme gleichzeitig gilt, statt jedes Gerät einzeln zu konfigurieren. 4. Level 1 ist breit anwendbar mit geringem Funktionsrisiko, Level 2 greift tiefer und kann Funktionen einschränken. 5. Eine fehlerhafte oder zu strikte Einstellung würde sofort alle Systeme betreffen; besser zunächst in einer separaten Testorganisationseinheit mit wenigen Testsystemen anwenden und beobachten.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] eine Baseline für alle drei Laborsysteme erstellt hast,
- [ ] mindestens eine CIS-Empfehlung manuell geprüft hast,
- [ ] erklären kannst, warum GPO-Verteilung Hardening beschleunigt,
- [ ] das Risiko einer unternehmensweiten Sofortverteilung einschätzen kannst.

Kapitel 2: Windows Security Baselines

Lernziele

- Du beziehst die Microsoft Security Baselines für die eigene Umgebung.
- Du importierst eine Baseline als GPO in Active Directory.
- Du vergleichst den Effekt einer Baseline gegen den unveränderten Ausgangszustand.

1. Einführung

Kapitel 1 hat das Prinzip erklärt. Dieses Kapitel macht daraus eine konkrete, importierbare Konfiguration statt einer manuellen Einzelprüfung.

2. Technische Grundlagen

Microsoft veröffentlicht für jede unterstützte Windows- und Windows-Server-Version eine Sammlung vorkonfigurierter GPO-Vorlagen über das **Security Compliance Toolkit**, das neben den Baselines selbst auch den **Policy Analyzer** zum Vergleich unterschiedlicher Konfigurationen enthält.

Beispiel 2.1: Baseline-GPOs mit LGPO.exe importieren (Konzept)

```
LGPO.exe /g "C:\Baselines\MSFT-Win11-24H2-Computer"
```

3. Fachbegriffe

LGPO.exe ist ein Microsoft-Kommandozeilenwerkzeug, das lokale Gruppenrichtlinienobjekte aus Textvorlagen importiert und exportiert. Der **Policy Analyzer** vergleicht mehrere GPO-Bestände nebeneinander und markiert Konflikte oder Abweichungen.

4. Praxis und Konfiguration

Beispiel 2.2: Eine Baseline als Domänen-GPO importieren

```
Gruppenrichtlinienverwaltung -> neues GPO erstellen -> "MSFT-Baseline-Clients"
-> GPO bearbeiten -> Richtlinienergebnisse importieren -> Baseline-Backup auswählen
```

Beispiel 2.3: Aktuelle Richtlinieneinstellungen eines Systems exportieren (Vergleichsgrundlage)

```
PS> gpresult /h vorher.html
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Verknüpfe eine neu importierte Baseline zunächst mit einer Testorganisationseinheit, die ausschließlich Testsysteme enthält, nie direkt mit der Domänenwurzel oder einer produktiv genutzten Organisationseinheit.

6. Praktische Laborübungen

Übung A: Baseline-GPO importieren und mit Testorganisationseinheit verknüpfen

Aufgabenstellung: Importiere eine Windows-11-Baseline und verknüpfe sie mit einer eigens angelegten Test-OU. **Ausgangssituation:** DC01 mit Active Directory, CLIENT01 als Domänenmitglied. **Voraussetzungen:** Baseline-Dateien von Microsoft bezogen (Security Compliance Toolkit). **Schritt-für-Schritt-Anleitung:** Test-OU anlegen, CLIENT01-Computerobjekt dorthin verschieben, Beispiel 2.2 durchführen, GPO mit der Test-OU verknüpfen. **Erwartetes Ergebnis:** `gpresult /r` auf CLIENT01 zeigt die neue GPO als angewendet. **Überprüfung:** Die Richtlinieneinstellungen stimmen mit der importierten Baseline überein. **Fehleranalyse:** GPO nicht angewendet? `gpupdate /force` auf CLIENT01 ausführen und Gruppenrichtlinien-Vererbung in der Verwaltungskonsole prüfen. **Musterlösung:** CLIENT01 zeigt nach `gpupdate /force` die neuen, aus der Baseline importierten Einstellungen.

Übung B: Vorher-Nachher-Vergleich dokumentieren

Aufgabenstellung: Exportiere die Richtlinienlage von CLIENT01 vor und nach der Baseline-Anwendung und vergleiche sie. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** Export aus Beispiel 2.3 vor Beginn von Übung A bereits vorhanden. **Schritt-für-Schritt-Anleitung:** `gpresult /h nachher.html` nach Übung A ausführen, beide HTML-Berichte nebeneinander vergleichen. **Erwartetes Ergebnis:** Mehrere neue, zusätzliche Richtlinieneinstellungen im „Nachher"-Bericht. **Überprüfung:** Jede neue Einstellung lässt sich der importierten Baseline zuordnen. **Fehleranalyse:** Keine Unterschiede? Prüfen, ob die GPO tatsächlich korrekt mit der Test-OU verknüpft wurde. **Musterlösung:** Ein dokumentierter Vergleich mit klar benannten, neu hinzugekommenen Einstellungen.

7. Typische Fehler

Fehler	Ursache	Behebung
GPO mit Domänenwurzel statt Test-OU verknüpft	Unachtsamkeit	immer zuerst Test-OU verwenden
`gpupdate /force` nach Änderung vergessen	Richtlinienaktualisierung läuft sonst erst später automatisch	nach jeder GPO-Änderung manuell aktualisieren
Vorher-Export vergessen	kein Vergleichspunkt vorhanden	Export immer vor der ersten Änderung durchführen

8. Zusammenfassung

Zusammenfassung

- Microsoft Security Baselines liegen als fertige GPO-Vorlagen im Security Compliance Toolkit vor.
- LGPO.exe importiert und exportiert lokale Gruppenrichtlinienobjekte.
- Neue Baselines gehören zunächst in eine isolierte Testorganisationseinheit.
- `gpresult` dokumentiert den Vorher-Nachher-Effekt einer Richtlinienänderung.

9. Kontrollfragen

1. Wie heißt die Microsoft-Sammlung mit fertigen Baseline-GPOs? (leicht)

2. Welcher Befehl aktualisiert Gruppenrichtlinien sofort? (leicht)
3. Wozu dient der Policy Analyzer? (mittel)
4. Warum sollte eine neue Baseline nie direkt mit der Domänenwurzel verknüpft werden? (mittel)
5. Nach dem Import einer Baseline funktioniert eine auf CLIENT01 benötigte Anwendung nicht mehr. Wie gehst du systematisch vor? (schwer)

Lösungshinweise: 1. Security Compliance Toolkit. 2. `gpupdate /force`. 3. Er vergleicht mehrere GPO-Bestände nebeneinander und markiert Konflikte oder Abweichungen. 4. Weil ein Fehler sonst sofort alle Domänenmitglieder betrifft, statt nur eine begrenzte Testgruppe. 5. Die Einstellung mit `gpresult /h` identifizieren, die für die Störung ursächlich sein könnte, testweise aus der Baseline-GPO entfernen oder per gezielter Ausnahme-GPO überschreiben, und erneut testen.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] eine Baseline erfolgreich als GPO importiert hast,
- [ ] sie mit einer Testorganisationseinheit statt der Domänenwurzel verknüpft hast,
- [ ] einen Vorher-Nachher-Vergleich dokumentiert hast,
- [ ] bei einer gestörten Anwendung systematisch die Ursache eingrenzen kannst.

Kapitel 3: PowerShell für Security Administration

Lernziele

- Du nutzt PowerShell Remoting für die Verwaltung mehrerer Systeme gleichzeitig.
- Du schreibst ein einfaches Skript zur Sicherheitsprüfung mehrerer Systeme.
- Du richtest eine eingeschränkte PowerShell-Sitzung (Constrained Endpoint) ein.

1. Einführung

Band 1 hat PowerShell auf einem einzelnen System genutzt. In einer Domäne mit mehreren Systemen wird PowerShell erst durch **Remoting** zum eigentlichen Verwaltungswerkzeug.

2. Technische Grundlagen

PowerShell Remoting (`WinRM`) erlaubt, Befehle auf einem oder mehreren entfernten Systemen auszuführen, als säße man lokal davor. Für Sicherheitsadministration besonders wertvoll: dieselbe Prüfung lässt sich mit einem einzigen Befehl gegen alle Domänenmitglieder gleichzeitig ausführen.

Beispiel 3.1: Einen Befehl auf mehreren Systemen gleichzeitig ausführen

```
PS> Invoke-Command -ComputerName DC01,SRV01,CLIENT01 -ScriptBlock {
    Get-HotFix | Select-Object -First 1 }
```

3. Fachbegriffe

Ein **Constrained Endpoint** beschränkt eine PowerShell-Remoting-Sitzung auf eine fest definierte Menge erlaubter Befehle, statt vollen Zugriff zu gewähren – ein Beispiel des Prinzips der geringsten Rechte, angewendet auf administrative Fernzugriffe. **JEA** (Just Enough Administration) baut dieses Konzept zu einem vollständigen Rollenmodell aus.

4. Praxis und Konfiguration

Beispiel 3.2: Ein einfaches Sicherheitsprüfskript für mehrere Systeme

```
PS> $Systeme = "DC01","SRV01","CLIENT01"
PS> Invoke-Command -ComputerName $Systeme -ScriptBlock {
    [PSCustomObject]@{
        System = $env:COMPUTERNAME
        Defender = (Get-MpComputerStatus).RealTimeProtectionEnabled
        LetztesUpdate = (Get-HotFix | Sort-Object InstalledOn -Descending |
            Select-Object -First 1).InstalledOn
    }
} | Format-Table -AutoSize
```

Beispiel 3.3: Einen Constrained Endpoint registrieren (Konzept)

```
PS> Register-PSSessionConfiguration -Name "Sicherheitspruefung" `
    -StartupScript "C:\Skripte\eingeschraenkt.ps1"
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

PowerShell Remoting ist standardmäßig nur innerhalb vertrauenswürdiger Domänen aktiviert. Aktiviere es niemals pauschal für alle Netzwerkprofile (Band 1, Kapitel 7) auf einem Gerät, das auch außerhalb der Domäne genutzt wird.

6. Praktische Laborübungen

Übung A: Remoting gegen alle drei Systeme einsetzen

Aufgabenstellung: Führe das Skript aus Beispiel 3.2 gegen alle drei Laborsysteme aus. **Ausgangssituation:** DC01, SRV01, CLIENT01 in der Domäne, Remoting aktiviert. **Voraussetzungen:** administrative Domänenanmeldung. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 3.2. **Erwartetes Ergebnis:** Eine Tabelle mit drei Zeilen, je System Defender-Status und letztem Update. **Überprüfung:** Die Werte stimmen mit einer manuellen Prüfung auf einem der Systeme überein. **Fehleranalyse:** „Access is denied“? Prüfen, ob `Enable-PSRemoting` auf dem Zielsystem aktiv ist und die Firewall-Regel „Windows Remote Management“ erlaubt ist. **Musterlösung:** Eine vollständige, dreizeilige Ergebnistabelle.

Übung B: Einen Constrained Endpoint einrichten

Aufgabenstellung: Richte einen eingeschränkten Endpoint ein, der nur Lesebefehle erlaubt, und teste ihn. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** Ein Startskript mit erlaubten Befehlen definieren, Beispiel 3.3 ausführen, mit `Enter-PSSession -ConfigurationName "Sicherheitspruefung"` testen. **Erwartetes Ergebnis:** Erlaubte Befehle funktionieren, nicht erlaubte werden abgelehnt. **Überprüfung:** Ein Testbefehl außerhalb der erlaubten Menge schlägt gezielt fehl. **Fehleranalyse:** Endpoint nicht erreichbar? `Get-PSSessionConfiguration` zur Diagnose nutzen. **Musterlösung:** Ein funktionierender, nachweislich eingeschränkter Endpoint.

7. Typische Fehler

Fehler	Ursache	Behebung
Remoting außerhalb der Domäne aktiv	Netzwerkprofil nicht beachtet	Remoting nur im Domänenprofil zulassen
Volles Remoting statt Constrained Endpoint für begrenzte Aufgaben	Bequemlichkeit	Endpoint auf tatsächlich benötigte Befehle beschränken
Skript gegen produktive Systeme ungetestet ausgeführt	fehlender Testlauf	zuerst gegen Testsysteme ausführen

8. Zusammenfassung

Zusammenfassung

- PowerShell Remoting erlaubt zentrale Verwaltung mehrerer Systeme mit einem Befehl.
- Constrained Endpoints und JEA beschränken Remoting-Zugriff auf das tatsächlich Nötige.

- Remoting sollte nur im vertrauenswürdigen Domänenprofil aktiv sein.
- Sicherheitsprüfskripte lassen sich mit `Invoke-Command` auf viele Systeme gleichzeitig anwenden.

9. Kontrollfragen

1. Welcher Befehl führt einen Befehl auf mehreren entfernten Systemen aus? (leicht)
2. Wofür steht JEA? (leicht)
3. Was ist ein Constrained Endpoint? (mittel)
4. Warum sollte Remoting nicht in allen Netzwerkprofilen aktiv sein? (mittel)
5. Ein Administrator benötigt für eine wiederkehrende Aufgabe nur Lesezugriff auf Ereignisprotokolle mehrerer Server. Wie würdest du den Zugriff technisch eng fassen? (schwer)

Lösungshinweise: 1. `Invoke-Command -ComputerName`. 2. Just Enough Administration. 3. Eine PowerShell-Remoting-Sitzung, die auf eine fest definierte Menge erlaubter Befehle beschränkt ist. 4. Weil sonst auch aus nicht vertrauenswürdigen Netzen administrativer Fernzugriff möglich wäre. 5. Einen Constrained Endpoint oder eine JEA-Rolle einrichten, die ausschließlich die zum Lesen von Ereignisprotokollen nötigen Cmdlets erlaubt, statt vollen administrativen Remoting-Zugriff zu gewähren.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] PowerShell Remoting gegen mehrere Systeme eingesetzt hast,
- [ ] ein einfaches Sicherheitsprüfskript geschrieben hast,
- [ ] einen Constrained Endpoint eingerichtet und getestet hast,
- [ ] erklären kannst, warum Remoting-Zugriff nach dem Prinzip der geringsten Rechte beschränkt werden sollte.

Kapitel 4: Gruppenrichtlinien (GPO)

Lernziele

- Du erstellst und verknüpfst ein GPO mit einer Organisationseinheit.
- Du erklärst Verarbeitungsreihenfolge und Vererbung von Gruppenrichtlinien.
- Du setzt eine Sicherheitsvorgabe per GPO durch und bestätigst ihre Wirkung.

1. Einführung

Kapitel 2 hat bereits eine fertige Baseline importiert. Dieses Kapitel erklärt das zugrunde liegende Werkzeug selbst: Gruppenrichtlinien, das zentrale Steuerungsinstrument jeder Active-Directory-Umgebung.

2. Technische Grundlagen

Ein **Gruppenrichtlinienobjekt** (GPO) bündelt Konfigurationseinstellungen und wird mit einem Container (Standort, Domäne oder Organisationseinheit) verknüpft. Mehrere verknüpfte GPOs verarbeiten sich in einer festen Reihenfolge, zusammengefasst als **LSDOU**: Local, Site, Domain, Organizational Unit – spätere Einstellungen überschreiben frühere bei Konflikten, sofern keine Vorrangregel (`Enforced`) dem entgegensteht.

Beispiel 4.1: Verarbeitungsreihenfolge (Konzept)

```
Lokale Richtlinie -> Standort-GPO -> Domänen-GPO -> GPO der Organisationseinheit
(die GPO der Organisationseinheit hat normalerweise die höchste Priorität)
```

3. Fachbegriffe

Eine **Organisationseinheit** (OU) strukturiert Active-Directory-Objekte hierarchisch und dient als Ziel für GPO-Verknüpfungen. `Enforced` erzwingt eine GPO-Einstellung gegen nachgelagerte, abweichende GPOs; `Block Inheritance` unterbricht die Vererbung übergeordneter GPOs für eine OU, wird aber durch `Enforced` wieder außer Kraft gesetzt.

4. Praxis und Konfiguration

Beispiel 4.2: Eine neue Organisationseinheit und ein GPO anlegen

```
PS> New-ADOrganizationalUnit -Name "Testclients" -Path "DC=nova,DC=int"
PS> New-GPO -Name "Bildschirmsperre-Testclients" |
    New-GPLink -Target "OU=Testclients,DC=nova,DC=int"
```

Beispiel 4.3: Eine konkrete Einstellung im GPO setzen

```
Gruppenrichtlinienverwaltungs-Editor -> Computerkonfiguration -> Richtlinien ->
Windows-Einstellungen -> Sicherheitseinstellungen -> Lokale Richtlinien ->
Sicherheitsoptionen -> "Interaktive Anmeldung: Inaktivitätslimit für den
Computer" -> Aktiviert, 600 Sekunden
```

> **Gut zu wissen**
>
> Die ältere, oft genannte Einstellung „Zeitlimit für Anmeldebildschirmschoner erzwingen“ unter den administrativen Vorlagen legt nur fest, nach welcher Zeit ein Bildschirmschoner aktiviert werden darf. Sie sperrt die Sitzung nicht von selbst, sondern erst in Kombination mit einem zusätzlich aktivierten, passwortgeschützten Bildschirmschoner. „Interaktive Anmeldung: Inaktivitätslimit für den Computer“ sperrt die Sitzung dagegen direkt nach der angegebenen Zeit, unabhängig von einer Bildschirmschoner-Konfiguration, und ist deshalb der zuverlässigere Weg für dieses Beispiel.

Beispiel 4.4: Wirksamkeit prüfen

```
PS> gpresult /r
```

5. Sicherheitsbetrachtung

> **WARNUNG – Sicherheitsrisiko**
>
> Verknüpfe eine neue, ungetestete GPO-Einstellung zunächst mit einer eigenen Test-OU, niemals direkt mit der Domänenwurzel. Ein Konfigurationsfehler in einer domänenweiten GPO betrifft sofort jedes Mitgliedsobjekt.

6. Praktische Laborübungen

Übung A: Eine eigene Test-OU mit GPO einrichten

Aufgabenstellung: Erstelle die OU und das GPO aus Beispiel 4.2, verschiebe CLIENT01 hinein, und setze die Bildschirmsperre nach Beispiel 4.3. **Ausgangssituation:** CLIENT01 in der Standard-OU „Computers“. **Voraussetzungen:** administrative Domänenrechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 4.2-4.4. **Erwartetes Ergebnis:** CLIENT01 sperrt den Bildschirm nach zehn Minuten Inaktivität. **Überprüfung:** `gpresult /r` zeigt das GPO als angewendet. **Fehleranalyse:** Keine Wirkung? `gpupdate /force` auf CLIENT01 ausführen und Computerobjekt-Position in Active Directory erneut prüfen. **Musterlösung:** Eine funktionierende, auf die Test-OU begrenzte Bildschirmsperre.

Übung B: Vererbung und Enforced testen

Aufgabenstellung: Erstelle ein zweites, widersprechendes GPO auf Domänenebene und beobachte, welches gewinnt, mit und ohne `Enforced`. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** Ein Domänen-GPO mit abweichendem Zeitlimit (z. B. 300 Sekunden) anlegen, Wirkung auf CLIENT01 prüfen, danach das Domänen-GPO auf „Enforced“ setzen und erneut prüfen. **Erwartetes Ergebnis:** Ohne „Enforced“ gewinnt die OU-Einstellung (600 Sekunden), mit „Enforced“ die Domänen-Einstellung (300 Sekunden). **Überprüfung:** `gpresult /h bericht.html` zeigt die tatsächlich wirksame Einstellung und ihre Quelle. **Fehleranalyse:** Unerwartetes Ergebnis? Verarbeitungsreihenfolge aus Beispiel 4.1 erneut gegen die eigene Konfiguration prüfen. **Musterlösung:** Eine dokumentierte Bestätigung der LSDOU-Reihenfolge und der Wirkung von „Enforced“.

7. Typische Fehler

Fehler	Ursache	Behebung
GPO direkt mit Domänenwurzel statt Test-OU verknüpft	Unachtsamkeit	immer zuerst mit Test-OU arbeiten
Unerwartetes Verhalten bei mehreren GPOs	Verarbeitungsreihenfolge nicht beachtet	LSDOU-Reihenfolge und Verknüpfungsreihenfolge innerhalb einer OU prüfen
`gpupdate /force` vergessen	Richtlinienaktualisierung läuft sonst erst beim nächsten Zyklus	nach jeder Teständerung manuell aktualisieren

8. Zusammenfassung

> **Zusammenfassung**
>
> - GPOs werden mit Containern verknüpft und nach der LSDOU-Reihenfolge verarbeitet.
> - `Enforced` erzwingt eine Einstellung gegen nachgelagerte, abweichende GPOs.
> - Neue GPOs gehören zunächst in eine isolierte Test-OU.
> - `gpresult` zeigt die tatsächlich wirksame Einstellung und ihre Quelle.

9. Kontrollfragen

1. Wofür steht LSDOU? (leicht)
2. Welcher Befehl aktualisiert Gruppenrichtlinien sofort? (leicht)
3. Was bewirkt die Einstellung „Enforced“? (mittel)
4. Was unterscheidet „Block Inheritance“ von „Enforced“, wenn beide gleichzeitig vorliegen? (mittel)
5. Zwei GPOs setzen widersprüchliche Werte für dieselbe Einstellung auf derselben OU-Ebene. Welche Regel entscheidet, und wie findest du das heraus? (schwer)

Lösungshinweise: 1. Local, Site, Domain, Organizational Unit – die Verarbeitungsreihenfolge von Gruppenrichtlinien. 2. `gpupdate /force`. 3. Es erzwingt die Einstellung gegen nachgelagerte, abweichende GPOs, auch wenn diese eigentlich Vorrang hätten. 4. „Enforced“ setzt sich gegen „Block Inheritance“ durch; die erzwungene Einstellung wirkt trotz unterbrochener Vererbung. 5. Die Verknüpfungsreihenfolge innerhalb derselben OU entscheidet (höher in der Liste gewinnt); mit `gpresult /h` lässt sich die tatsächlich wirksame GPO und ihre Herkunft nachvollziehen.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] ein GPO erstellt und mit einer Test-OU verknüpft hast,
- [ ] eine konkrete Sicherheitseinstellung erfolgreich durchgesetzt hast,
- [ ] die LSDOU-Verarbeitungsreihenfolge erklären kannst,
- [ ] die Wirkung von „Enforced“ und „Block Inheritance“ gegeneinander einschätzen kannst.

Kapitel 5: Active Directory Security

Lernziele

- Du erklärst die Rolle privilegierter Gruppen in Active Directory.
- Du setzt das Prinzip der geringsten Rechte auf Domänenadministration an.
- Du richtest eine delegierte Berechtigung für eine eingeschränkte administrative Aufgabe ein.

1. Einführung

Active Directory selbst ist die kritischste Komponente der gesamten Domäne: Wer AD kontrolliert, kontrolliert jedes Mitgliedsgerät. Dieses Kapitel behandelt, wie sich dieser zentrale Angriffspunkt gezielt absichern lässt.

2. Technische Grundlagen

Active Directory bringt hochprivilegierte, integrierte Gruppen mit: **Domain Admins** (volle Rechte in der gesamten Domäne), **Enterprise Admins** (volle Rechte über mehrere Domänen einer Gesamtstruktur hinweg), **Schema Admins** (Rechte zur Änderung der AD-Struktur selbst).

Beispiel 5.1: Mitglieder privilegierter Gruppen anzeigen

```
PS> Get-ADGroupMember -Identity "Domain Admins"
PS> Get-ADGroupMember -Identity "Enterprise Admins"
```

3. Fachbegriffe

Delegation überträgt eine eng begrenzte administrative Aufgabe (z. B. Passwort-Reset für eine bestimmte OU) an ein Konto, ohne volle Domain-Admin-Rechte zu vergeben. Der **AdminSDHolder**-Mechanismus schützt hochprivilegierte Konten automatisch mit einer festen Berechtigungsvorlage, die periodisch wiederhergestellt wird.

4. Praxis und Konfiguration

Beispiel 5.2: Delegation für Passwort-Reset einrichten

```
Active Directory-Benutzer und -Computer -> Test-OU -> Rechtsklick ->
"Steuerung delegieren" -> Benutzer/Gruppe wählen -> "Kennwörter der Benutzer zurücksetzen"
```

Beispiel 5.3: Mitgliedschaft in Domain Admins minimal halten

```
PS> Get-ADGroupMember -Identity "Domain Admins" | Select-Object Name, SamAccountName
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Jedes zusätzliche Mitglied der Gruppe Domain Admins vergrößert die Angriffsfläche der gesamten Domäne erheblich. Nutze für alltägliche administrative Aufgaben delegierte, eng begrenzte Berechtigungen statt pauschaler Domain-Admin-Mitgliedschaft.

6. Praktische Laborübungen

Übung A: Privilegierte Gruppen dokumentieren

Aufgabenstellung: Dokumentiere alle Mitglieder von Domain Admins und Enterprise Admins mit Begründung. **Ausgangssituation:** DC01 mit Standard-AD-Installation. **Voraussetzungen:** administrative Domänenrechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 5.1. **Erwartetes Ergebnis:** Eine vollständige Liste, typischerweise nur das initiale Administrator-Konto. **Überprüfung:** Jedes gelistete Konto hat eine nachvollziehbare Begründung. **Fehleranalyse:** Unerwartetes Mitglied? Prüfen, wann und durch wen es hinzugefügt wurde (Audit-Protokoll, Kapitel 14). **Musterlösung:** Eine dokumentierte, minimal besetzte Liste beider Gruppen.

Übung B: Delegierte Berechtigung einrichten und testen

Aufgabenstellung: Richte eine delegierte Berechtigung für Passwort-Reset in der Test-OU ein und teste sie mit einem eingeschränkten Konto. **Ausgangssituation:** Test-OU aus Kapitel 4, ein Testkonto ohne Domain-Admin-Rechte. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 5.2, danach mit dem delegierten Konto einen Passwort-Reset für ein Testkonto in derselben OU versuchen. **Erwartetes Ergebnis:** Der Passwort-Reset gelingt, andere administrative Aktionen (z. B. ein neues Konto anlegen) schlagen weiterhin fehl. **Überprüfung:** Das delegierte Konto kann ausschließlich die zugewiesene Aktion durchführen. **Fehleranalyse:** Kein Erfolg? Delegation erneut über den Assistenten prüfen, korrekte OU-Auswahl bestätigen. **Musterlösung:** Ein funktionierendes, eng begrenztes delegiertes Recht.

7. Typische Fehler

Fehler	Ursache	Behebung
Alltagskonto Mitglied von Domain Admins	Bequemlichkeit	delegierte, eng begrenzte Rechte statt voller Mitgliedschaft nutzen
Delegation zu breit gefasst	mehrere Rechte statt nur das benötigte ausgewählt	Delegationsassistent gezielt nur für den konkreten Bedarf durchlaufen
Privilegierte Gruppen nie überprüft	fehlende Routine	regelmäßige Revision wie in Übung A einplanen

8. Zusammenfassung

Zusammenfassung

- Domain Admins und Enterprise Admins sind die höchstprivilegierten AD-Gruppen und sollten minimal besetzt bleiben.
- Delegation überträgt eng begrenzte administrative Aufgaben ohne volle Rechtevergabe.
- AdminSDHolder schützt hochprivilegierte Konten mit einer festen Berechtigungsvorlage.
- Regelmäßige Revision privilegierter Gruppen gehört zur laufenden AD-Sicherheit.

9. Kontrollfragen

1. Was unterscheidet Domain Admins von Enterprise Admins? (leicht)
2. Welcher Befehl zeigt Mitglieder einer AD-Gruppe? (leicht)
3. Was ist Delegation im AD-Kontext? (mittel)
4. Wozu dient der AdminSDHolder-Mechanismus? (mittel)
5. Ein IT-Mitarbeiter soll nur Passwörter für eine bestimmte Abteilungs-OU zurücksetzen können. Warum ist Domain-Admin-Mitgliedschaft dafür unangemessen, und was ist die richtige Lösung? (schwer)

Lösungshinweise: 1. Domain Admins haben volle Rechte in einer Domäne, Enterprise Admins über mehrere Domänen einer Gesamtstruktur hinweg. 2. `Get-ADGroupMember`. 3. Die Übertragung einer eng begrenzten administrativen Aufgabe ohne volle Rechtevergabe. 4. Er schützt hochprivilegierte Konten automatisch mit einer festen, periodisch wiederhergestellten Berechtigungsvorlage. 5. Domain-Admin-Mitgliedschaft würde weit über die benötigte Aufgabe hinausgehende Rechte für die gesamte Domäne vergeben; die richtige Lösung ist eine Delegation genau dieser einen Aktion für genau diese eine OU.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] privilegierte Gruppen dokumentiert und bewertet hast,
- [ ] eine delegierte Berechtigung eingerichtet und erfolgreich getestet hast,
- [ ] den Unterschied zwischen Domain Admins und Enterprise Admins erklären kannst,
- [ ] erklären kannst, warum Delegation gegenüber voller Gruppenmitgliedschaft vorzuziehen ist.

Kapitel 6: Benutzer- und Gruppenverwaltung

Lernziele

- Du legst Domänenbenutzer und -gruppen per PowerShell an.
- Du nutzt verschachtelte Gruppen zur strukturierten Rechtevergabe.
- Du setzt Passwort-Richtlinien gezielt für eine Teilmenge von Konten um.

1. Einführung

Band 1, Kapitel 3 hat lokale Konten behandelt. In einer Domäne verwaltet Active Directory Benutzer und Gruppen zentral, mit eigenen Werkzeugen und zusätzlichen Strukturierungsmöglichkeiten.

2. Technische Grundlagen

Domänenbenutzer und -gruppen werden über das **ActiveDirectory**-PowerShell-Modul verwaltet. Gruppen lassen sich **verschachteln**: Eine Gruppe kann Mitglied einer anderen Gruppe sein, was komplexe Rechtestrukturen übersichtlicher macht, aber auch unübersichtlicher werden kann, wenn sie unkontrolliert wächst.

Beispiel 6.1: Domänenbenutzer und -gruppe anlegen

```
PS> New-ADUser -Name "Test Benutzer" -SamAccountName "testuser2" -Enabled $true `
    -AccountPassword (ConvertTo-SecureString "Tr4kt0r!Werk2026" -AsPlainText -Force)
PS> New-ADGroup -Name "Projektteam" -GroupScope Global -Path "OU=Testclients,DC=nova,DC=int"
PS> Add-ADGroupMember -Identity "Projektteam" -Members "testuser2"
```

Gut zu wissen

Das Passwort steht hier nur zu Demonstrationszwecken im Klartext. `-AsPlainText` ist laut Microsoft-Dokumentation nicht für Produktivskripte gedacht. Frage das Passwort in eigenen Skripten stattdessen interaktiv mit `Read-Host -AsSecureString` oder über `Get-Credential` ab.

3. Fachbegriffe

Ein **Fine-Grained Password Policy** (FGPP) erlaubt, abweichend von der domänenweiten Standardrichtlinie, strengere Passwortanforderungen für eine bestimmte Gruppe (z. B. Administratoren) festzulegen. Der **GroupScope** (Domänenlokal, Global, Universal) bestimmt, wo eine Gruppe Mitglieder aufnehmen und wo sie Rechte vergeben kann.

4. Praxis und Konfiguration

Beispiel 6.2: Eine strengere Passwort-Richtlinie für eine Gruppe einrichten

```
PS> New-ADFineGrainedPasswordPolicy -Name "StrengePW-Admins" -Precedence 10 `
    -MinPasswordLength 16 -ComplexityEnabled $true -MaxPasswordAge "30.00:00:00"
PS> Add-ADFineGrainedPasswordPolicySubject -Identity "StrengePW-Admins" -Subjects "Projektteam"
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Unkontrolliert verschachtelte Gruppen erschweren die Nachvollziehbarkeit, wer letztlich über welche Rechte verfügt. Dokumentiere jede Verschachtelung und prüfe regelmäßig, ob sie noch dem ursprünglichen Zweck entspricht.

6. Praktische Laborübungen

Übung A: Domänenbenutzer, Gruppe und Verschachtelung einrichten

Aufgabenstellung: Lege Benutzer und Gruppe nach Beispiel 6.1 an und verschachtle „Projektteam“ zusätzlich in eine bereits bestehende, übergeordnete Gruppe. **Ausgangssituation:** Test-OU aus Kapitel 4. **Voraussetzungen:** administrative Domänenrechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 6.1, danach `Add-ADGroupMember` für die Verschachtelung in eine zweite, selbst angelegte Gruppe anwenden. **Erwartetes Ergebnis:** `Get-ADGroupMember -Identity <uebergeordnete Gruppe> -Recursive` zeigt `testuser2` indirekt als Mitglied. **Überprüfung:** Die rekursive Abfrage bestätigt die indirekte Mitgliedschaft. **Fehleranalyse:** Kein Treffer? `-Recursive`-Parameter nicht vergessen, da direkte Abfragen verschachtelte Mitglieder sonst nicht zeigen. **Musterlösung:** Eine dokumentierte, nachvollziehbare Verschachtelungsstruktur.

Übung B: Fine-Grained Password Policy einrichten und testen

Aufgabenstellung: Richte die strengere Richtlinie aus Beispiel 6.2 ein und teste sie mit einem zu schwachen Testpasswort. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 6.2, danach Passwortänderung für `testuser2` mit einem kürzeren, einfacheren Passwort versuchen. **Erwartetes Ergebnis:** Das zu schwache Passwort wird abgelehnt, obwohl es die domänenweite Standardrichtlinie erfüllen würde. **Überprüfung:** `Get-ADUserResultantPasswordPolicy -Identity testuser2` zeigt die strengere, gruppenspezifische Richtlinie als wirksam. **Fehleranalyse:** Standardrichtlinie greift weiterhin? `Precedence`-Wert und korrekte Gruppenmitgliedschaft prüfen. **Musterlösung:** Eine bestätigte, gezielt nur für diese Gruppe wirksame, strengere Passwortrichtlinie.

7. Typische Fehler

Fehler	Ursache	Behebung
Verschachtelung ohne Dokumentation gewachsen	fehlende Übersicht	jede Verschachtelung mit Zweck dokumentieren
FGPP ohne Wirkung	falscher `Precedence`-Wert oder falsches Subjekt	mit `Get-ADUserResultantPasswordPolicy` die tatsächlich wirksame Richtlinie prüfen
GroupScope falsch gewählt	Unterschiede zwischen Domänenlokal/Global/Universal nicht beachtet	Scope anhand des tatsächlichen Verwendungszwecks wählen

8. Zusammenfassung

Zusammenfassung

- Das ActiveDirectory-PowerShell-Modul verwaltet Domänenbenutzer und -gruppen zentral.
- Verschachtelte Gruppen strukturieren Rechte, sollten aber dokumentiert bleiben.
- Fine-Grained Password Policies erlauben strengere Anforderungen für bestimmte Gruppen.
- `Get-ADUserResultantPasswordPolicy` zeigt die tatsächlich wirksame Richtlinie.

9. Kontrollfragen

1. Welches PowerShell-Modul verwaltet Active-Directory-Objekte? (leicht)
2. Wofür steht FGPP? (leicht)
3. Warum braucht eine rekursive Gruppenabfrage den Parameter `-Recursive`? (mittel)
4. Wozu dient der `Precedence`-Wert bei einer Fine-Grained Password Policy? (mittel)
5. Zwei Fine-Grained Password Policies gelten für dasselbe Konto über verschiedene Gruppenmitgliedschaften. Welche gewinnt, und wie findest du das heraus? (schwer)

Lösungshinweise: 1. Das ActiveDirectory-Modul. 2. Fine-Grained Password Policy. 3. Weil eine direkte Abfrage nur unmittelbare, nicht aber über weitere Gruppen vermittelte Mitgliedschaften zeigt. 4. Er legt die Priorität fest, wenn mehrere Richtlinien für dasselbe Konto gelten könnten; ein niedrigerer Wert gewinnt. 5. Die Richtlinie mit dem niedrigeren `Precedence`-Wert gewinnt; herausfinden lässt sich das mit `Get-ADUserResultantPasswordPolicy -Identity <konto>`.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] einen Domänenbenutzer und eine Gruppe angelegt hast,
- [ ] eine Gruppenverschachtelung eingerichtet und rekursiv geprüft hast,
- [ ] eine Fine-Grained Password Policy eingerichtet und verifiziert hast,
- [ ] erklären kannst, wie der Precedence-Wert über mehrere geltende Richtlinien entscheidet.

Kapitel 7: Kerberos und NTLM

Lernziele

- Du erklärst den grundsätzlichen Ablauf einer Kerberos-Authentifizierung.
- Du erkennst, wann ein System auf das schwächere NTLM zurückfällt.
- Du schränkst NTLM-Nutzung gezielt per GPO ein.

1. Einführung

Band 1, Kapitel 6 hat beide Protokolle nur erwähnt. In einer Domäne sind sie der zentrale Mechanismus, über den sich jede Anmeldung tatsächlich vollzieht.

2. Technische Grundlagen

Kerberos ist das moderne, Standard-Authentifizierungsprotokoll in Active Directory: Ein Client erhält von einem **Key Distribution Center** (auf dem Domain Controller) ein zeitlich begrenztes **Ticket Granting Ticket (TGT)**, mit dem er anschließend Dienst-Tickets für einzelne Ressourcen anfordert, ohne das Passwort erneut zu übertragen. **NTLM** ist das ältere Protokoll, das Windows aus Kompatibilitätsgründen weiterhin unterstützt, aber als weniger sicher gilt.

Beispiel 7.1: Kerberos-Ablauf (stark vereinfacht)

```
Client -> AS-REQ -> Domain Controller (Authentication Service)
Client <- TGT    <- Domain Controller
Client -> TGS-REQ (mit TGT) -> Domain Controller (Ticket Granting Service)
Client <- Dienst-Ticket <- Domain Controller
Client -> Dienst-Ticket -> Zielserver (z. B. SRV01)
```

3. Fachbegriffe

Ein **Pass-the-Hash**-Angriff (vertieft in Band 3) nutzt aus, dass NTLM einen Passwort-Hash statt des Passworts selbst zur Authentifizierung verwendet, wodurch ein gestohlener Hash ausreicht, um sich auszugeben. Der **NTLM-Fallback** tritt ein, wenn Kerberos aus technischen Gründen (z. B. fehlende Namensauflösung) nicht funktioniert und das System automatisch auf NTLM zurückgreift.

4. Praxis und Konfiguration

Beispiel 7.2: NTLM-Nutzung im Netzwerk protokollieren (vor Einschränkung)

```
GPO -> Computerkonfiguration -> Richtlinien -> Windows-Einstellungen ->
Sicherheitseinstellungen -> Lokale Richtlinien -> Sicherheitsoptionen ->
"Netzwerksicherheit: Restrict NTLM: NTLM-Überwachung" -> Alle aktivieren
```

Beispiel 7.3: NTLM-Ereignisse im Protokoll einsehen

```
PS> Get-WinEvent -LogName "Microsoft-Windows-NTLM/Operational" -MaxEvents 20
```

5. Sicherheitsbetrachtung

> **WARNUNG – Sicherheitsrisiko**
>
> Deaktiviere NTLM niemals abrupt domänenweit, ohne vorher mit Protokollierung (Beispiel 7.2/7.3) geprüft zu haben, welche Systeme oder Anwendungen noch tatsächlich darauf angewiesen sind. Ältere Anwendungen oder Geräte können sonst unerwartet den Dienst verweigern.

6. Praktische Laborübungen

Übung A: NTLM-Nutzung im Labor protokollieren

Aufgabenstellung: Aktiviere NTLM-Überwachung und identifiziere, ob und wo NTLM im Labor noch genutzt wird. **Ausgangssituation:** DC01, SRV01, CLIENT01 in der Domäne. **Voraussetzungen:** administrative Domänenrechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 7.2, danach einige Tage oder gezielte Testzugriffe abwarten, dann Beispiel 7.3 auf den relevanten Systemen ausführen. **Erwartetes Ergebnis:** Eine Liste protokollierter NTLM-Ereignisse, im gut konfigurierten Labor idealerweise selten. **Überprüfung:** Jedes gefundene Ereignis lässt sich einem konkreten System oder Vorgang zuordnen. **Fehleranalyse:** Keine Ereignisse trotz erwarteter NTLM-Nutzung? Protokollierungsstufe (Beispiel 7.2) erneut prüfen. **Musterlösung:** Eine dokumentierte Übersicht tatsächlicher NTLM-Nutzung im Labor.

Übung B: Kerberos-Tickets einsehen

Aufgabenstellung: Zeige die aktuell gültigen Kerberos-Tickets einer Sitzung an. **Ausgangssituation:** Eine angemeldete Sitzung auf CLIENT01. **Voraussetzungen:** keine besonderen.
Schritt-für-Schritt-Anleitung:

Befehl zu Übung B

```
PS> klist
```

Erwartetes Ergebnis: Eine Liste aktueller Tickets, darunter das TGT (`krbtgt`) und Dienst-Tickets für genutzte Ressourcen. **Überprüfung:** Nach Zugriff auf eine Freigabe auf SRV01 erscheint ein neues Dienst-Ticket dafür. **Fehleranalyse:** Keine Tickets sichtbar? Prüfen, ob die Anmeldung tatsächlich über die Domäne erfolgte, nicht lokal. **Musterlösung:** Eine dokumentierte Ticket-Liste mit Erklärung von TGT und mindestens einem Dienst-Ticket.

7. Typische Fehler

Fehler	Ursache	Behebung
NTLM abrupt deaktiviert	fehlende vorherige Analyse	zuerst protokollieren, dann schrittweise einschränken
Kerberos-Probleme auf NTLM-Fallback zurückgeführt, ohne Ursache zu suchen	Symptom statt Ursache behandelt	meist liegt die eigentliche Ursache bei DNS oder Zeitsynchronisation
`klist`-Ausgabe nicht verstanden	fehlende Erklärung der Feldbedeutung	TGT und Dienst-Tickets gezielt unterscheiden

8. Zusammenfassung

Zusammenfassung

- Kerberos nutzt TGT und Dienst-Tickets, ohne das Passwort wiederholt zu übertragen.
- NTLM ist älter, schwächer und sollte schrittweise statt abrupt eingeschränkt werden.
- NTLM-Überwachung zeigt vor jeder Einschränkung, wo das Protokoll noch tatsächlich gebraucht wird.
- `klist` macht aktuelle Kerberos-Tickets einer Sitzung sichtbar.

9. Kontrollfragen

1. Was ist ein TGT? (leicht)
2. Welcher Befehl zeigt aktuelle Kerberos-Tickets? (leicht)
3. Wann greift ein System auf NTLM statt Kerberos zurück? (mittel)
4. Warum sollte NTLM nicht abrupt domänenweit deaktiviert werden? (mittel)
5. Kerberos-Authentifizierung schlägt auf SRV01 unerwartet fehl, NTLM funktioniert aber weiterhin. Welche zwei häufigen Ursachen prüfst du zuerst? (schwer)

Lösungshinweise: 1. Ticket Granting Ticket, das erste, vom Domain Controller ausgestellte Ticket einer Kerberos-Sitzung. 2. `klist`. 3. Wenn Kerberos aus technischen Gründen, etwa fehlender Namensauflösung, nicht funktioniert. 4. Weil ältere Anwendungen oder Geräte noch darauf angewiesen sein können und sonst unerwartet ausfallen. 5. DNS-Konfiguration (Kerberos ist auf korrekte Namensauflösung angewiesen) und Zeitsynchronisation zwischen den Systemen (Kerberos toleriert nur eine begrenzte Zeitabweichung).

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] NTLM-Nutzung im Labor protokolliert und ausgewertet hast,
- [ ] Kerberos-Tickets mit `klist` eingesehen hast,
- [ ] den grundsätzlichen Kerberos-Ablauf erklären kannst,
- [ ] erklären kannst, warum NTLM schrittweise statt abrupt eingeschränkt werden sollte.

Kapitel 8: SMB-Sicherheit

Lernziele

- Du erklärst, warum SMBv1 als unsicher gilt und deaktiviert werden sollte.
- Du prüfst und erzwingst SMB-Signierung in der Domäne.
- Du richtest eine Freigabe mit angemessenen Berechtigungen ein.

1. Einführung

SMB (Band 1, Kapitel 7 kurz erwähnt) ist das Protokoll hinter nahezu jeder Datei- und Druckerfreigabe in einer Windows-Domäne – und war historisch Ziel schwerwiegender, breit ausgenutzter Schwachstellen.

2. Technische Grundlagen

SMBv1, das älteste noch unterstützte Protokoll, gilt seit Jahren als unsicher und war unter anderem die Grundlage weitreichender, öffentlich bekannt gewordener Schadsoftware-Ausbrüche. Seit Windows Server 2016 bzw. Windows 10 ist SMBv1 standardmäßig deaktiviert, kann aber bei älteren Umgebungen noch aktiv sein.

Beispiel 8.1: SMB-Protokollversionen prüfen

```
PS> Get-SmbServerConfiguration | Select-Object EnableSMB1Protocol, EnableSMB2Protocol
```

3. Fachbegriffe

SMB-Signierung fügt jeder SMB-Nachricht eine kryptografische Signatur hinzu, die Manipulation auf dem Übertragungsweg erkennbar macht. **SMB-Verschlüsselung** (ab SMBv3) verschlüsselt zusätzlich den gesamten Inhalt der Kommunikation.

4. Praxis und Konfiguration

Beispiel 8.2: SMBv1 deaktivieren

```
PS> Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol
```

Beispiel 8.3: SMB-Signierung erzwingen (per GPO)

```
Computerkonfiguration -> Richtlinien -> Windows-Einstellungen -> Sicherheitseinstellungen ->
Lokale Richtlinien -> Sicherheitsoptionen ->
"Microsoft-Netzwerk (Server): Kommunikation digital signieren (immer)" -> Aktiviert
```

Beispiel 8.4: Eine Freigabe mit angemessenen Berechtigungen einrichten

```
PS> New-SmbShare -Name "Projektdaten" -Path "C:\Projekt" -FullAccess "nova\Projektteam"
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Prüfe vor der Deaktivierung von SMBv1, ob tatsächlich keine älteren Geräte (z. B. ältere Netzwerkdrucker oder NAS-Systeme) noch darauf angewiesen sind. Ein ungeplanter Ausfall solcher Geräte lässt sich leicht vermeiden, wenn vorher geprüft wird.

6. Praktische Laborübungen

Übung A: SMBv1 prüfen und deaktivieren

Aufgabenstellung: Prüfe den SMB-Protokollstatus auf SRV01 und deaktiviere SMBv1, falls noch aktiv. **Ausgangssituation:** SRV01 nach Standardinstallation. **Voraussetzungen:** administrative Rechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 8.1, 8.2. **Erwartetes Ergebnis:** `EnableSMB1Protocol` zeigt `False` nach der Änderung. **Überprüfung:** Ein erneuter Abruf von Beispiel 8.1 bestätigt den Zustand. **Fehleranalyse:** Feature lässt sich nicht deaktivieren? Neustart nach `Disable-WindowsOptionalFeature` erforderlich. **Musterlösung:** SMBv1 ist deaktiviert, SMBv2/v3 bleiben aktiv.

Übung B: Freigabe einrichten und SMB-Signierung erzwingen

Aufgabenstellung: Richte die Freigabe aus Beispiel 8.4 ein, erzwinge SMB-Signierung per GPO, und bestätige den Zugriff vom Domänenmitglied CLIENT01 aus. **Ausgangssituation:** Gruppe „Projektteam“ aus Kapitel 6. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 8.3, 8.4, danach von CLIENT01 aus mit einem Mitglied von „Projektteam“ auf die Freigabe zugreifen. **Erwartetes Ergebnis:** Der Zugriff gelingt; `Get-SmbConnection` auf CLIENT01 zeigt eine signierte Verbindung. **Überprüfung:** Ein Konto außerhalb von „Projektteam“ erhält keinen Zugriff auf die Freigabe. **Fehleranalyse:** Zugriff verweigert trotz Gruppenmitgliedschaft? NTFS-Rechte (Band 1, Kapitel 5) zusätzlich zur Freigabeberechtigung prüfen. **Musterlösung:** Eine funktionierende, signierte Freigabe mit korrekt begrenztem Zugriff.

7. Typische Fehler

Fehler	Ursache	Behebung
SMBv1 ohne vorherige Prüfung deaktiviert	Abhängigkeit älterer Geräte übersehen	vor Deaktivierung Geräteinventar prüfen
SMB-Signierung nur auf einem System erzwungen	GPO nicht domänenweit oder auf relevante OU angewendet	GPO-Verknüpfung auf alle relevanten Systeme ausweiten
Freigabeberechtigung ohne NTFS-Abgleich gesetzt	Band-1-Wissen nicht angewendet	stets restriktivere Kombination aus beiden prüfen

8. Zusammenfassung

Zusammenfassung

- SMBv1 gilt als unsicher und sollte, nach Prüfung der Abhängigkeiten, deaktiviert werden.
- SMB-Signierung erkennt Manipulation auf dem Übertragungsweg, SMB-Verschlüsselung schützt zusätzlich den Inhalt.

- Freigaben sollten mit eng begrenzten Gruppen statt breiter Zugriffsrechte eingerichtet werden.
- Freigabe- und NTFS-Berechtigungen wirken immer in Kombination, die restriktivere gilt.

9. Kontrollfragen

1. Warum gilt SMBv1 als unsicher? (leicht)
2. Welcher Befehl deaktiviert SMBv1? (leicht)
3. Was unterscheidet SMB-Signierung von SMB-Verschlüsselung? (mittel)
4. Seit welcher Windows-Version ist SMBv1 standardmäßig deaktiviert? (mittel)
5. Ein altes Netzwerkgerät funktioniert nach der SMBv1-Deaktivierung nicht mehr. Welche zwei grundsätzlichen Lösungswege gibt es, ohne SMBv1 dauerhaft wieder zu aktivieren? (schwer)

Lösungshinweise: 1. Es war Grundlage weitreichender, öffentlich bekannter Schadsoftware-Ausbrüche und gilt als veraltet und unsicher. 2. `Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`. 3. Signierung erkennt Manipulation, Verschlüsselung schützt zusätzlich die Vertraulichkeit des Inhalts. 4. Seit Windows Server 2016 bzw. Windows 10. 5. Das Gerät durch ein neueres, SMBv2/v3-fähiges Modell ersetzen, oder es in ein isoliertes Netzwerksegment ohne Verbindung zu kritischen Systemen verschieben, statt SMBv1 im gesamten Netz wieder zu aktivieren.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] SMBv1 geprüft und sicher deaktiviert hast,
- [ ] eine Freigabe mit angemessenen Berechtigungen eingerichtet hast,
- [ ] SMB-Signierung per GPO erzwungen und bestätigt hast,
- [ ] eine Alternative zur SMBv1-Reaktivierung bei Altgeräten nennen kannst.

Kapitel 9: Windows Defender Firewall im Unternehmen

Lernziele

- Du verteilst Firewall-Regeln zentral per GPO statt pro Gerät.
- Du richtest eine Regel ein, die nur für Domänenmitglieder gilt.
- Du überwachst Firewall-Ereignisse zentral.

1. Einführung

Band 1, Kapitel 9 hat Firewall-Regeln lokal auf einem einzelnen Gerät erstellt. In einer Domäne lassen sich dieselben Regeln zentral verteilen, konsistent für viele Geräte gleichzeitig.

2. Technische Grundlagen

Firewall-Regeln lassen sich als Teil eines GPO definieren und automatisch auf jedes Gerät in der verknüpften OU anwenden. Das **Domäne**-Netzwerkprofil (Band 1, Kapitel 7) greift automatisch, sobald ein Gerät bei einem Domain Controller angemeldet ist.

Beispiel 9.1: Firewall-Regel als GPO-Element definieren

```
GPO bearbeiten -> Computerkonfiguration -> Richtlinien -> Windows-Einstellungen ->
Sicherheitseinstellungen -> Windows Defender Firewall mit erweiterter Sicherheit ->
Eingehende Regeln -> Neue Regel -> Port 445 (SMB) -> nur für Profil "Domäne"
```

3. Fachbegriffe

Zentralisierte Richtlinienverwaltung bezeichnet den Ansatz, Firewall- und andere Sicherheitsregeln einmalig über GPO zu definieren statt gerätespezifisch. **IPsec-Regeln** (vertiefter Ausblick) erlauben zusätzlich, Verbindungen nicht nur zuzulassen oder zu blockieren, sondern zu authentifizieren und zu verschlüsseln.

4. Praxis und Konfiguration

Beispiel 9.2: Firewall-Status aller Domänenmitglieder zentral prüfen

```
PS> Invoke-Command -ComputerName DC01,SRV01,CLIENT01 -ScriptBlock {
    Get-NetFirewallProfile -Name Domain | Select-Object Name, Enabled, DefaultInboundAction
}
```

Beispiel 9.3: Firewall-Protokollierung aktivieren

```
PS> Set-NetFirewallProfile -Profile Domain -LogAllowed True -LogBlocked True `
    -LogFileName "%systemroot%\system32\LogFiles\Firewall\pfirewall.log"
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Eine zentral verteilte, fehlerhafte Firewall-Regel betrifft sofort alle Domänenmitglieder der verknüpften OU. Teste neue Regeln, wie bei jeder GPO-Änderung, zunächst in einer separaten Test-OU.

6. Praktische Laborübungen

Übung A: Firewall-Regel zentral per GPO verteilen

Aufgabenstellung: Verteile eine SMB-Regel ausschließlich für das Domänenprofil nach Beispiel 9.1 an die Test-OU. **Ausgangssituation:** Test-OU aus Kapitel 4, CLIENT01 darin. **Voraussetzungen:** administrative Domänenrechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 9.1, danach `gpupdate /force` auf CLIENT01. **Erwartetes Ergebnis:** Die Regel erscheint auf CLIENT01 unter den eingehenden Regeln, als von der Domäne verwaltet gekennzeichnet. **Überprüfung:** `Get-NetFirewallRule -PolicyStoreSourceType GroupPolicy` zeigt die Regel. **Fehleranalyse:** Regel nicht sichtbar? OU-Verknüpfung und Computerobjekt-Position erneut prüfen. **Musterlösung:** Eine zentral verteilte, auf CLIENT01 wirksame Firewall-Regel.

Übung B: Firewall-Status zentral abfragen und protokollieren

Aufgabenstellung: Prüfe den Firewall-Status aller drei Systeme gleichzeitig und aktiviere zentrale Protokollierung. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A, PowerShell Remoting aktiv (Kapitel 3). **Schritt-für-Schritt-Anleitung:** siehe Beispiel 9.2, dann 9.3 auf jedem System. **Erwartetes Ergebnis:** Eine Statusübersicht für alle drei Systeme, danach aktive Protokollierung erlaubter und blockierter Verbindungen. **Überprüfung:** Die Protokolldatei füllt sich nach einiger Zeit mit Einträgen. **Fehleranalyse:** Keine Einträge? Pfad und Dateirechte der Protokolldatei prüfen. **Musterlösung:** Eine zentrale Statusübersicht und aktive, auswertbare Firewall-Protokollierung.

7. Typische Fehler

Fehler	Ursache	Behebung
Regel versehentlich für alle Profile statt nur Domäne verteilt	Profilangabe vergessen	Profil in der Regel explizit auf „Domäne“ beschränken
Fehlerhafte Regel sofort unternehmensweit wirksam	kein Testlauf vorgeschaltet	immer zuerst Test-OU nutzen
Protokollierung aktiviert, aber nie ausgewertet	fehlende Routine	regelmäßige Auswertung einplanen (vertieft in Kapitel 14-15)

8. Zusammenfassung

Zusammenfassung

- Firewall-Regeln lassen sich per GPO zentral statt gerätespezifisch verteilen.
- Das Domänenprofil greift automatisch bei angemeldeten Domänenmitgliedern.
- `Invoke-Command` erlaubt, den Firewall-Status vieler Systeme gleichzeitig zu prüfen.
- Jede zentral verteilte Regel verdient denselben vorsichtigen Testlauf wie eine lokale.

9. Kontrollfragen

1. Wie lassen sich Firewall-Regeln zentral statt pro Gerät verteilen? (leicht)
2. Welches Netzwerkprofil greift bei angemeldeten Domänenmitgliedern automatisch? (leicht)
3. Warum sollte eine neue, zentral verteilte Regel zunächst in einer Test-OU geprüft werden? (mittel)
4. Wie lässt sich der Firewall-Status mehrerer Systeme gleichzeitig abfragen? (mittel)
5. Eine zentral verteilte Firewall-Regel blockiert unerwartet eine geschäftskritische Anwendung auf allen Domänenmitgliedern gleichzeitig. Was ist der schnellste, sichere Rückweg? (schwer)

Lösungshinweise: 1. Über ein GPO, verknüpft mit der relevanten Organisationseinheit. 2. Das Domäne-Profil. 3. Weil ein Fehler sonst sofort alle Mitglieder der OU gleichzeitig betrifft. 4. Mit `Invoke-Command` und `Get-NetFirewallProfile` gegen mehrere Systeme gleichzeitig. 5. Die fehlerhafte GPO-Verknüpfung umgehend entfernen oder das GPO deaktivieren, dann `gpupdate /force` auf den betroffenen Systemen ausführen, um die alte Regel schnellstmöglich zurückzunehmen.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] eine Firewall-Regel zentral per GPO verteilt hast,
- [ ] den Firewall-Status mehrerer Systeme gleichzeitig geprüft hast,
- [ ] zentrale Firewall-Protokollierung aktiviert hast,
- [ ] einen schnellen Rückweg bei einer fehlerhaften, zentral verteilten Regel nennen kannst.

Kapitel 10: Microsoft Defender und Endpoint Protection

Lernziele

- Du verteilst Defender-Konfiguration zentral per GPO.
- Du richtest Attack Surface Reduction-Regeln ein.
- Du ordnest Microsoft Defender for Endpoint gegenüber dem integrierten Defender ein.

1. Einführung

Band 1, Kapitel 8 hat Defender auf einem einzelnen Gerät konfiguriert. Dieses Kapitel zeigt die zentrale Verteilung und ergänzende, unternehmensorientierte Schutzfunktionen.

2. Technische Grundlagen

Attack Surface Reduction (ASR)-Regeln blockieren gezielt bestimmte, häufig für Angriffe missbrauchte Verhaltensweisen (z. B. Office-Anwendungen, die Kindprozesse starten), unabhängig von einer konkreten Signatur. **Microsoft Defender for Endpoint** erweitert den integrierten Defender um zentrale Cloud-Verwaltung, erweiterte Erkennung und Reaktionsfunktionen (EDR) für größere Umgebungen; es ist ein separates, lizenzpflichtiges Produkt.

Beispiel 10.1: Defender-Konfiguration zentral per GPO (Konzept)

```
Computerkonfiguration -> Richtlinien -> Administrative Vorlagen ->
Windows-Komponenten -> Microsoft Defender Antivirus ->
"Echtzeitschutz aktivieren" -> Aktiviert
```

3. Fachbegriffe

EDR (Endpoint Detection and Response) geht über klassischen Virenschutz hinaus und beobachtet Systemverhalten kontinuierlich, um auch unbekannte, signaturlose Bedrohungen anhand verdächtiger Verhaltensmuster zu erkennen. Eine **ASR-Regel** lässt sich im Testmodus (Audit) oder im durchsetzenden Modus (Block) betreiben.

4. Praxis und Konfiguration

Beispiel 10.2: Eine ASR-Regel im Testmodus aktivieren

```
PS> Add-MpPreference -AttackSurfaceReductionRules_Ids BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550 `
    -AttackSurfaceReductionRules_Actions AuditMode
```

Beispiel 10.3: ASR-Ereignisse auswerten

```
PS> Get-WinEvent -LogName "Microsoft-Windows-Windows Defender/Operational" |
    Where-Object { $_.Id -eq 1121 -or $_.Id -eq 1122 }
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Aktiviere neue ASR-Regeln immer zuerst im Audit-Modus und prüfe die protokollierten Ereignisse, bevor du auf „Block“ umstellst. Eine zu aggressive Regel kann sonst legitime, geschäftskritische Arbeitsabläufe unterbrechen.

6. Praktische Laborübungen

Übung A: Defender-Konfiguration zentral verteilen

Aufgabenstellung: Verteile die Defender-Konfiguration aus Beispiel 10.1 an die Test-OU. **Ausgangssituation:** Test-OU aus Kapitel 4. **Voraussetzungen:** administrative Domänenrechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 10.1, danach `gpupdate /force` auf CLIENT01. **Erwartetes Ergebnis:** `Get-MpComputerStatus` auf CLIENT01 bestätigt den zentral gesetzten Echtzeitschutz-Status. **Überprüfung:** Die Einstellung lässt sich lokal auf CLIENT01 nicht mehr manuell deaktivieren (als „von Richtlinie verwaltet“ markiert). **Fehleranalyse:** Einstellung weiterhin lokal änderbar? GPO-Verknüpfung und Richtlinienanwendung erneut prüfen. **Musterlösung:** Eine zentral erzwungene, lokal nicht umgehbare Defender-Einstellung.

Übung B: ASR-Regel im Testmodus einrichten und auswerten

Aufgabenstellung: Aktiviere eine ASR-Regel im Audit-Modus und werte die protokollierten Ereignisse aus. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 10.2, danach typische Office-Nutzung simulieren, dann Beispiel 10.3 ausführen. **Erwartetes Ergebnis:** Event-ID 1122 (Audit-Treffer) erscheint bei einem passenden, im Testmodus erkannten Verhalten. **Überprüfung:** Die protokollierten Ereignisse lassen sich konkreten, nachvollziehbaren Aktionen zuordnen. **Fehleranalyse:** Keine Ereignisse? GUID der Regel gegen die offizielle Microsoft-Dokumentation prüfen. **Musterlösung:** Eine dokumentierte Entscheidungsgrundlage, ob die Regel sicher auf „Block“ umgestellt werden kann.

7. Typische Fehler

Fehler	Ursache	Behebung
ASR-Regel direkt im Block-Modus aktiviert	Testphase übersprungen	immer zuerst Audit-Modus nutzen
Defender for Endpoint mit integriertem Defender verwechselt	ähnlicher Name, unterschiedlicher Funktionsumfang	integrierter Defender ist kostenlos enthalten, for Endpoint ist ein separates, lizenzpflichtiges Produkt
GPO-Einstellung lokal überschrieben	Richtlinie nicht als „erzwungen“ konfiguriert	zentrale Einstellung so konfigurieren, dass sie lokale Änderung verhindert

8. Zusammenfassung

Zusammenfassung

- Defender-Konfiguration lässt sich zentral per GPO verteilen und lokal unveränderbar machen.
- ASR-Regeln blockieren verdächtige Verhaltensmuster unabhängig von einer konkreten Signatur.

- Neue ASR-Regeln gehören zuerst in den Audit-, dann erst in den Block-Modus.
- Microsoft Defender for Endpoint ergänzt den integrierten Defender um zentrale EDR-Funktionen.

9. Kontrollfragen

1. Wofür steht ASR? (leicht)
2. Was unterscheidet den Audit- vom Block-Modus einer ASR-Regel? (leicht)
3. Was ist EDR? (mittel)
4. Warum ist Defender for Endpoint nicht dasselbe wie der integrierte Defender? (mittel)
5. Eine ASR-Regel im Audit-Modus zeigt über mehrere Tage keine einzige Protokollmeldung. Was schließt du daraus, und was prüfst du als Nächstes? (schwer)

Lösungshinweise: 1. Attack Surface Reduction. 2. Audit protokolliert nur, Block verhindert das erkannte Verhalten tatsächlich. 3. Endpoint Detection and Response, kontinuierliche Verhaltensbeobachtung zur Erkennung auch unbekannter Bedrohungen. 4. Defender for Endpoint ist ein separates, lizenzpflichtiges Produkt mit zentraler Cloud-Verwaltung und erweiterten Reaktionsfunktionen, der integrierte Defender ist kostenlos in Windows enthalten. 5. Entweder tritt das von der Regel adressierte Verhalten im Labor schlicht nicht auf (ein plausibles, positives Ergebnis), oder die Regel ist nicht korrekt aktiv; als Nächstes mit `Get-MpPreference` prüfen, ob die Regel tatsächlich im konfigurierten Modus aktiv ist.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] Defender-Konfiguration zentral per GPO verteilt hast,
- [ ] eine ASR-Regel im Audit-Modus eingerichtet und ausgewertet hast,
- [ ] den Unterschied zwischen integriertem Defender und Defender for Endpoint erklären kannst,
- [ ] eine fehlende Protokollmeldung systematisch hinterfragen kannst.

Kapitel 11: BitLocker und Gerätesicherheit

Lernziele

- Du zentralisierst BitLocker-Wiederherstellungsschlüssel in Active Directory.
- Du erzwingst BitLocker per GPO für Domänenmitglieder.
- Du stellst einen Wiederherstellungsschlüssel aus Active Directory wieder her.

1. Einführung

Band 1, Kapitel 12 hat BitLocker auf einem Einzelgerät eingerichtet, mit lokal gesichertem Schlüssel. In einer Domäne lässt sich diese Sicherung zentralisieren – wichtig, sobald mehrere Geräte verwaltet werden.

2. Technische Grundlagen

Active Directory kann BitLocker-Wiederherstellungsschlüssel automatisch beim jeweiligen Computerobjekt hinterlegen (**BitLocker Recovery Password Viewer**), sodass ein Administrator den Schlüssel zentral abrufen kann, ohne auf eine lokale Sicherung beim Gerät selbst angewiesen zu sein.

Beispiel 11.1: Wiederherstellungsschlüssel aus Active Directory abrufen

```
PS> Get-ADObject -Filter {objectclass -eq 'msFVE-RecoveryInformation'} `
    -SearchBase "CN=CLIENT01,OU=Testclients,DC=nova,DC=int" -Properties msFVE-RecoveryPassword
```

3. Fachbegriffe

Backup to AD bezeichnet den Mechanismus, mit dem ein Client seinen BitLocker-Schlüssel automatisch an Active Directory überträgt. Das **BitLocker Recovery Password Viewer**-Feature muss auf dem Domain Controller zunächst installiert werden, um Schlüssel über die GUI komfortabel einsehen zu können.

4. Praxis und Konfiguration

Beispiel 11.2: BitLocker-Speicherung in AD per GPO erzwingen

```
Computerkonfiguration -> Richtlinien -> Administrative Vorlagen -> Windows-Komponenten ->
BitLocker-Laufwerkverschlüsselung -> Betriebssystemlaufwerke ->
"Wiederherstellungsinformationen in AD DS speichern" -> Aktiviert, "Sicherung erforderlich"
```

Beispiel 11.3: BitLocker Recovery Password Viewer auf DC01 installieren

```
PS> Install-WindowsFeature -Name RSAT-Feature-Tools-BitLocker
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Der Zugriff auf in Active Directory gespeicherte Wiederherstellungsschlüssel ist selbst ein hochsensibles Recht. Beschränke es per Delegation (Kapitel 5) auf einen klar begrenzten Personenkreis, nicht auf alle administrativen Konten pauschal.

6. Praktische Laborübungen

Übung A: BitLocker-Speicherung in AD erzwingen und testen

Aufgabenstellung: Konfiguriere die GPO aus Beispiel 11.2, aktiviere BitLocker auf CLIENT01 (Band 1, Kapitel 12), und bestätige die Speicherung in AD. **Ausgangssituation:** Test-OU aus Kapitel 4, CLIENT01 darin. **Voraussetzungen:** administrative Domänenrechte, TPM aktiviert. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 11.2, dann 11.3 auf DC01, danach BitLocker auf CLIENT01 aktivieren oder bestehende Verschlüsselung neu synchronisieren (`manage-bde -protectors -adbackup C:`). **Erwartetes Ergebnis:** Beispiel 11.1 zeigt einen gespeicherten Wiederherstellungsschlüssel für CLIENT01. **Überprüfung:** Der angezeigte Schlüssel lässt sich zur Entsperrung des Laufwerks tatsächlich verwenden. **Fehleranalyse:** Kein Eintrag in AD? Prüfen, ob die GPO bereits vor der BitLocker-Aktivierung wirksam war, oder manuelle Synchronisation nachholen. **Musterlösung:** Ein in AD zentral gespeicherter, abrufbarer Wiederherstellungsschlüssel.

Übung B: Wiederherstellung über Active Directory simulieren

Aufgabenstellung: Sperre das BitLocker-Laufwerk auf CLIENT01 und stelle es mit dem aus AD abgerufenen Schlüssel wieder her. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** Laufwerk sperren, Schlüssel über das BitLocker Recovery Password Viewer-Snap-In oder Beispiel 11.1 abrufen, Entsperrung durchführen. **Erwartetes Ergebnis:** Erfolgreiche Entsperrung ausschließlich mit dem aus AD abgerufenen Schlüssel. **Überprüfung:** Kein Rückgriff auf eine lokal gespeicherte Kopie nötig. **Fehleranalyse:** Schlüssel passt nicht? Prüfen, ob es sich um den aktuellsten, nicht einen älteren, bereits rotierten Schlüssel handelt. **Musterlösung:** Eine erfolgreiche, vollständig AD-gestützte Wiederherstellung.

7. Typische Fehler

Fehler	Ursache	Behebung
GPO erst nach BitLocker-Aktivierung eingerichtet	Reihenfolge nicht beachtet	GPO-Konfiguration vor der Verschlüsselung vorsehen, sonst manuell nachsynchronisieren
Zugriff auf Wiederherstellungsschlüssel zu breit delegiert	fehlende Eingrenzung	Delegation auf einen klar begrenzten Personenkreis beschränken
BitLocker Recovery Password Viewer nicht installiert	Feature standardmäßig nicht vorhanden	Beispiel 11.3 vor der ersten Nutzung ausführen

8. Zusammenfassung

Zusammenfassung

- Active Directory kann BitLocker-Wiederherstellungsschlüssel zentral speichern.
- Eine GPO kann diese Speicherung domänenweit erzwingen.

- Der Zugriff auf gespeicherte Schlüssel ist ein hochsensibles, eng zu delegierendes Recht.
- Eine Wiederherstellung lässt sich vollständig ohne lokal gespeicherte Kopie durchführen.

9. Kontrollfragen

1. Wie heißt der Mechanismus, der BitLocker-Schlüssel automatisch in AD speichert? (leicht)
2. Welches Feature muss auf dem Domain Controller installiert werden, um Schlüssel komfortabel einzusehen? (leicht)
3. Warum sollte der Zugriff auf Wiederherstellungsschlüssel eng delegiert werden? (mittel)
4. Was tust du, wenn eine GPO zur AD-Speicherung erst nach der BitLocker-Aktivierung eingerichtet wurde? (mittel)
5. Ein Unternehmen verwaltet hunderte BitLocker-geschützte Geräte ohne zentrale Schlüsselspeicherung. Welches konkrete betriebliche Risiko ergibt sich daraus? (schwer)

Lösungshinweise: 1. Backup to AD. 2. BitLocker Recovery Password Viewer. 3. Weil ein Wiederherstellungsschlüssel vollen Zugriff auf ein verschlüsseltes Laufwerk ermöglicht und damit selbst hochsensibel ist. 4. Die Synchronisation mit `manage-bde -protectors -adbackup` manuell nachholen. 5. Bei einem vergessenen Passwort, einer Hardwareänderung oder einem technischen Defekt gibt es ohne zentrale Speicherung keinen zuverlässigen, skalierbaren Weg, den jeweiligen Schlüssel wiederzufinden, was zu dauerhaftem Datenverlust führen kann.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] BitLocker-Speicherung in AD per GPO erzwungen hast,
- [ ] einen Wiederherstellungsschlüssel zentral aus AD abgerufen hast,
- [ ] eine vollständige Wiederherstellung ohne lokale Schlüsselkopie durchgeführt hast,
- [ ] das Risiko fehlender zentraler Schlüsselspeicherung einschätzen kannst.

Kapitel 12: Windows-Dienste und Prozesssicherheit

Lernziele

- Du identifizierst unnötig laufende Dienste auf einem Server systematisch.
- Du härtest einen Dienst mit einem dedizierten, eingeschränkten Dienstkonto.
- Du nutzt Managed Service Accounts als sicherere Alternative zu klassischen Dienstkonten.

1. Einführung

Band 1, Kapitel 2 hat Dienstkontexte eingeführt. Auf einem Server wie SRV01, der mehrere Anwendungen gleichzeitig bedient, wird die Härtung einzelner Dienste besonders wichtig.

2. Technische Grundlagen

Ein klassisches **Dienstkonto** ist ein reguläres AD-Konto, dessen Passwort manuell verwaltet werden muss. Ein **Group Managed Service Account (gMSA)** löst dieses Problem: Active Directory verwaltet das Passwort automatisch, rotiert es regelmäßig, ohne dass ein Administrator es kennen oder manuell ändern muss.

Beispiel 12.1: Unnötige Dienste auf SRV01 identifizieren

```
PS> Get-Service | Where-Object { $_.Status -eq "Running" } | Select-Object Name, DisplayName
```

3. Fachbegriffe

Ein **gMSA** kann von mehreren Servern gemeinsam genutzt werden (z. B. in einer Lastverteilungsgruppe), ein **standalone Managed Service Account (sMSA)** ist auf einen einzelnen Server beschränkt. Beide Kontotypen können sich nicht interaktiv anmelden, was sie gegenüber klassischen Dienstkonten erheblich sicherer macht.

4. Praxis und Konfiguration

Beispiel 12.2: Einen gMSA erstellen und einem Dienst zuweisen

```
PS> New-ADServiceAccount -Name "svc-webapp" -DNSHostName "srv01.nova.int" `
    -PrincipalsAllowedToRetrieveManagedPassword "SRV01$"
PS> Install-ADServiceAccount -Identity "svc-webapp"
```

Beispiel 12.3: Einem Dienst das gMSA zuweisen (Dienste-Snap-In oder PowerShell)

```
PS> sc.exe config "MeinDienst" obj= "nova\svc-webapp$" password= ""
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Ein klassisches Dienstkonto mit einem nie geänderten, oft Jahre altem Passwort ist ein beliebtes Ziel: Wird es einmal kompromittiert, bleibt es es oft unbemerkt gültig. gMSAs beseitigen dieses Risiko strukturell, indem sie manuelle Passwortverwaltung überflüssig machen.

6. Praktische Laborübungen

Übung A: Laufende Dienste auf SRV01 systematisch prüfen

Aufgabenstellung: Erstelle eine vollständige Liste laufender Dienste auf SRV01 und identifiziere nicht benötigte. **Ausgangssituation:** SRV01 nach Standardinstallation. **Voraussetzungen:** administrative Rechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 12.1. **Erwartetes Ergebnis:** Eine vollständige, begründete Liste. **Überprüfung:** Jeder Dienst hat eine nachvollziehbare Begründung für seinen aktiven Zustand. **Fehleranalyse:** Unklarer Dienst? `Get-Service -Name <name> | Select-Object DisplayName` zur Identifikation nutzen. **Musterlösung:** Eine dokumentierte, bereinigte Dienstliste.

Übung B: Einen gMSA erstellen und einem Testdienst zuweisen

Aufgabenstellung: Erstelle einen gMSA nach Beispiel 12.2 und weise ihn einem Testdienst auf SRV01 zu. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** administrative Domänenrechte, KDS-Root-Key bereits vorhanden (`Add-KdsRootKey -EffectiveTime ((Get-Date).AddHours(-10))` im Testlabor, da die normale Wartezeit von 10 Stunden dort umgangen werden kann).
Schritt-für-Schritt-Anleitung: siehe Beispiel 12.2, 12.3. **Erwartetes Ergebnis:** Der Testdienst startet erfolgreich unter dem gMSA-Konto, ohne dass ein Passwort manuell hinterlegt wurde. **Überprüfung:** `Get-Service` zeigt den Dienst als laufend, `Get-ADServiceAccount` bestätigt die Existenz des Kontos. **Fehleranalyse:** Dienst startet nicht? Prüfen, ob `PrincipalsAllowedToRetrieveManagedPassword` tatsächlich den Servernamen (mit `$`) enthält. **Musterlösung:** Ein funktionierender Dienst unter einem automatisch verwalteten gMSA-Konto.

7. Typische Fehler

Fehler	Ursache	Behebung
Nicht benötigter Dienst dauerhaft aktiv belassen	fehlende regelmäßige Prüfung	Dienstliste wiederkehrend gegen Übung A abgleichen
Klassisches Dienstkonto mit nie geändertem Passwort	fehlende Routine zur Passwortrotation	wo möglich auf gMSA umstellen
KDS-Root-Key-Wartezeit im Labor nicht beachtet	Produktionszeitplan unreflektiert übernommen	im isolierten Testlabor die Wartezeit per `-EffectiveTime` verkürzen

8. Zusammenfassung

Zusammenfassung

- Nicht benötigte Dienste sollten systematisch identifiziert und deaktiviert werden.
- Group Managed Service Accounts verwalten ihr Passwort automatisch und rotieren es regelmäßig.
- gMSAs können sich nicht interaktiv anmelden, was sie gegenüber klassischen Dienstkonten sicherer macht.
- Ein klassisches, nie geändertes Dienstkontopasswort ist ein beliebtes, strukturelles Risiko.

9. Kontrollfragen

1. Was unterscheidet einen gMSA von einem klassischen Dienstkonto? (leicht)
2. Welcher Befehl erstellt einen neuen gMSA? (leicht)
3. Warum können sich gMSAs nicht interaktiv anmelden, und warum ist das ein Sicherheitsvorteil? (mittel)
4. Was unterscheidet einen gMSA von einem sMSA? (mittel)
5. Ein Dienst läuft seit Jahren unter einem klassischen Dienstkonto mit demselben Passwort. Welche konkreten Schritte würdest du für die Umstellung auf ein gMSA planen? (schwer)

Lösungshinweise: 1. Ein gMSA verwaltet sein Passwort automatisch über Active Directory, statt es manuell zu pflegen. 2. `New-ADServiceAccount`. 3. Sie sind ausschließlich für Dienste vorgesehen; ohne interaktive Anmeldung verringert sich die Angriffsfläche, selbst wenn Zugangsdaten bekannt würden. 4. Ein gMSA kann von mehreren Servern gemeinsam genutzt werden, ein sMSA ist auf einen einzelnen Server beschränkt. 5. KDS-Root-Key prüfen oder anlegen, gMSA erstellen und dem Server-Computerkonto die Abrufberechtigung erteilen, den Dienst in einem Wartungsfenster auf das neue Konto umstellen und testen, und erst danach das alte, klassische Dienstkonto deaktivieren.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] laufende Dienste auf einem Server systematisch geprüft hast,
- [ ] einen gMSA erstellt und einem Dienst zugewiesen hast,
- [ ] den Sicherheitsvorteil fehlender interaktiver Anmeldung erklären kannst,
- [ ] eine Umstellung von klassischem Dienstkonto auf gMSA planen kannst.

Kapitel 13: AppLocker und Windows Defender Application Control

Lernziele

- Du erklärst den Unterschied zwischen Allowlisting und klassischem Virenschutz.
- Du richtest eine AppLocker-Regel im Audit-Modus ein.
- Du ordnest WDAC gegenüber AppLocker ein.

1. Einführung

Defender (Kapitel 10) erkennt bekannte oder verdächtige Schadsoftware. **AppLocker** verfolgt einen entgegengesetzten Ansatz: Es erlaubt von vornherein nur ausdrücklich zugelassene Software, alles andere wird blockiert.

2. Technische Grundlagen

Allowlisting (auch Whitelisting) kehrt das übliche Sicherheitsmodell um: Statt bekannte Bedrohungen zu blockieren, wird nur bekannte, vertrauenswürdige Software ausdrücklich zugelassen. AppLocker definiert Regeln nach Herausgeber, Pfad oder Datei-Hash.

Beispiel 13.1: AppLocker-Regeln auf Basis vorhandener Software automatisch generieren

```
Lokale Sicherheitsrichtlinie -> Anwendungssteuerungsrichtlinien -> AppLocker ->
Ausführbare Regeln -> Automatisch Regeln generieren
-> Ordner auswählen (z. B. C:\Program Files)
```

3. Fachbegriffe

WDAC (Windows Defender Application Control) ist der modernere, kernelbasierte Nachfolger von AppLocker mit stärkerer, nicht umgehbarer Durchsetzung, aber komplexerer Konfiguration. AppLocker bleibt für viele Unternehmensumgebungen wegen seiner einfacheren Verwaltung weiterhin relevant.

4. Praxis und Konfiguration

Beispiel 13.2: Den AppLocker-Dienst aktivieren und Regeln im Audit-Modus testen

```
PS> Set-Service -Name AppIDSvc -StartupType Automatic
PS> Start-Service -Name AppIDSvc
```

Beispiel 13.3: AppLocker-Ereignisse auswerten

```
PS> Get-WinEvent -LogName "Microsoft-Windows-AppLocker/EXE and DLL" -MaxEvents 20
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Aktiviere AppLocker-Regeln niemals direkt im durchsetzenden Modus, ohne vorher im Audit-Modus geprüft zu haben, welche tatsächlich genutzte Software dadurch blockiert würde. Eine zu strikte Regel kann sonst geschäftskritische Anwendungen lahmlegen.

6. Praktische Laborübungen

Übung A: AppLocker-Regeln automatisch generieren und im Audit-Modus testen

Aufgabenstellung: Generiere Regeln für CLIENT01 nach Beispiel 13.1 und aktiviere den AppLocker-Dienst im Audit-Modus. **Ausgangssituation:** CLIENT01 in der Test-OU. **Voraussetzungen:** administrative Rechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 13.1, 13.2. **Erwartetes Ergebnis:** Eine vollständige Regelsammlung basierend auf der vorhandenen Software. **Überprüfung:** Die generierten Regeln decken die üblicherweise genutzten Programme ab. **Fehleranalyse:** Dienst startet nicht? Prüfen, ob die Windows-Edition AppLocker unterstützt (Windows 11 Pro unterstützt AppLocker eingeschränkt gegenüber Enterprise). **Musterlösung:** Eine vollständige, im Audit-Modus aktive Regelsammlung.

Übung B: Ein nicht zugelassenes Programm testen und auswerten

Aufgabenstellung: Führe ein nicht in den Regeln erfasstes Programm aus und werte das Audit-Ereignis aus. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** Ein portables, nicht in `Program Files` installiertes Testprogramm ausführen, danach Beispiel 13.3. **Erwartetes Ergebnis:** Ein Audit-Ereignis zeigt, dass das Programm im durchsetzenden Modus blockiert worden wäre. **Überprüfung:** Das Ereignis benennt korrekt Programmpfad und betroffene Regel. **Fehleranalyse:** Kein Ereignis? Prüfen, ob der AppIDSvc-Dienst tatsächlich läuft. **Musterlösung:** Ein dokumentiertes Audit-Ereignis als Entscheidungsgrundlage für eine mögliche spätere Durchsetzung.

7. Typische Fehler

Fehler	Ursache	Behebung
Durchsetzender Modus ohne Audit-Phase aktiviert	Testlauf übersprungen	immer zuerst Audit, dann Durchsetzung
AppLocker und WDAC verwechselt	ähnlicher Zweck, unterschiedliche Technik	AppLocker ist einfacher, WDAC kernelbasiert und stärker durchsetzend
Regeln nie aktualisiert	neue, legitime Software nicht nachgetragen	Regelsatz bei neuer Softwareeinführung erneuern

8. Zusammenfassung

Zusammenfassung

- Allowlisting erlaubt nur ausdrücklich zugelassene Software, statt bekannte Bedrohungen zu blockieren.
- AppLocker definiert Regeln nach Herausgeber, Pfad oder Hash.
- WDAC ist der modernere, kernelbasierte, aber komplexer zu konfigurierende Nachfolger.
- Neue Regeln gehören zunächst in den Audit-, erst danach in den durchsetzenden Modus.

9. Kontrollfragen

1. Was ist Allowlisting? (leicht)
2. Wofür steht WDAC? (leicht)
3. Was unterscheidet den Audit- vom durchsetzenden Modus bei AppLocker? (mittel)
4. Warum gilt WDAC als stärker durchsetzend als AppLocker? (mittel)
5. Ein Unternehmen führt eine neue, geschäftskritische Anwendung ein, nachdem AppLocker-Regeln bereits durchsetzend aktiv sind. Was passiert, und wie bereitest du dich darauf vor? (schwer)

Lösungshinweise: 1. Nur ausdrücklich zugelassene Software darf ausgeführt werden, alles andere wird blockiert. 2. Windows Defender Application Control. 3. Audit protokolliert nur, der durchsetzende Modus blockiert tatsächlich. 4. Weil es kernelbasiert arbeitet und sich schwerer umgehen lässt als die eher benutzermodusbasierte Durchsetzung von AppLocker. 5. Die neue Anwendung würde ohne passende Regel blockiert; vorbereiten lässt sich das, indem man vor der Einführung eine passende Regel (nach Herausgeber oder Hash) ergänzt und sie zunächst im Audit-Modus testet.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] AppLocker-Regeln automatisch generiert hast,
- [ ] ein Audit-Ereignis für ein nicht zugelassenes Programm ausgewertet hast,
- [ ] AppLocker und WDAC in ihrem jeweiligen Einsatzzweck einordnest,
- [ ] eine Regelanpassung vor Einführung neuer Software planen kannst.

Kapitel 14: Windows Event Logging

Lernziele

- Du aktivierst erweiterte Überwachungsrichtlinien per GPO.
- Du richtest Event-Forwarding zur zentralen Sammlung ein.
- Du erstellst eine Aufgabenplanung, die auf ein bestimmtes Ereignis reagiert.

1. Einführung

Band 1, Kapitel 11 hat lokale Protokollauswertung behandelt. In einer Domäne lassen sich Protokolle zentral sammeln, statt jedes System einzeln zu prüfen – die Grundlage für Sysmon (Kapitel 15) und spätere forensische Arbeit (Band 3).

2. Technische Grundlagen

Erweiterte Überwachungsrichtlinien (Advanced Audit Policy) erlauben deutlich feinere Kontrolle darüber, was protokolliert wird, als die einfache, klassische Überwachungsrichtlinie. **Windows Event Forwarding (WEF)** sendet Ereignisse von vielen Quellsystemen automatisch an einen zentralen Sammler.

Beispiel 14.1: Erweiterte Überwachungsrichtlinie per GPO aktivieren

```
Computerkonfiguration -> Richtlinien -> Windows-Einstellungen -> Sicherheitseinstellungen ->
Erweiterte Überwachungsrichtlinienkonfiguration -> Anmelden/Abmelden ->
"Anmeldung überwachen" -> Erfolg und Fehler
```

3. Fachbegriffe

Ein **Sammler** (Collector) nimmt über WEF weitergeleitete Ereignisse zentral entgegen. Ein **Abonnement** (Subscription) definiert, welche Ereignisse von welchen Quellsystemen gesammelt werden.

4. Praxis und Konfiguration

Beispiel 14.2: Windows Event Collector auf DC01 einrichten

```
PS> wecutil qc
```

Beispiel 14.3: Ein Abonnement für fehlgeschlagene Anmeldungen erstellen (Konzept)

```
Ereignisanzeige -> Abonnements -> Abonnement erstellen ->
Quellcomputer: SRV01, CLIENT01 -> Ereignis-ID 4625 aus dem Security-Log
```

Beispiel 14.4: Eine Aufgabe erstellen, die auf ein Ereignis reagiert

```
PS> $Trigger = New-ScheduledTaskTrigger -Once -At (Get-Date)
PS> schtasks /create /tn "AlarmBeiFehlversuch" /tr "notepad.exe" /sc ONEVENT `
    /ec Security /mo "*[System[(EventID=4625)]]"
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Zentral gesammelte Protokolle sind selbst ein attraktives Ziel: Wer Schreibzugriff auf den Sammler erlangt, kann dort ankommende Beweise verfälschen oder löschen. Schütze den Sammler mit denselben, konsequenten Zugriffsbeschränkungen wie einen Domain Controller.

6. Praktische Laborübungen

Übung A: Erweiterte Überwachung und Event Forwarding einrichten

Aufgabenstellung: Aktiviere die erweiterte Überwachungsrichtlinie und richte DC01 als Event Collector ein. **Ausgangssituation:** DC01, SRV01, CLIENT01 in der Domäne. **Voraussetzungen:** administrative Domänenrechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 14.1, 14.2. **Erwartetes Ergebnis:** DC01 ist als Event Collector betriebsbereit. **Überprüfung:** `wecutil qc` meldet erfolgreiche Konfiguration. **Fehleranalyse:** Fehler bei der Einrichtung? Firewall-Regel „Windows-Remoteverwaltung“ auf den Quellsystemen prüfen (WEF nutzt WinRM). **Musterlösung:** Ein funktionsbereiter, zentraler Event Collector.

Übung B: Ein Abonnement einrichten und testen

Aufgabenstellung: Richte das Abonnement aus Beispiel 14.3 ein und löse testweise fehlgeschlagene Anmeldungen auf SRV01 aus. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 14.3, danach einige Fehlversuche auf SRV01 provozieren. **Erwartetes Ergebnis:** Die Ereignisse erscheinen im „Weitergeleitete Ereignisse“-Protokoll auf DC01. **Überprüfung:** Zeitstempel und Quellsystem im weitergeleiteten Ereignis stimmen mit dem tatsächlichen Vorgang überein. **Fehleranalyse:** Keine Weiterleitung? Abonnementstatus in der Ereignisanzeige auf „Aktiv“ prüfen. **Musterlösung:** Eine zentrale, funktionierende Sammlung fehlgeschlagener Anmeldeversuche von mehreren Quellsystemen.

7. Typische Fehler

Fehler	Ursache	Behebung
WEF richtet sich nicht ein	WinRM/Firewall auf Quellsystemen nicht konfiguriert	entsprechende Firewall-Regeln aktivieren
Sammler ohne besonderen Schutz betrieben	Bedeutung des Sammlers unterschätzt	Zugriffsrechte wie bei einem Domain Controller behandeln
Erweiterte Überwachung ohne klassische Richtlinie kombiniert	Konflikt zwischen beiden Systemen	ausschließlich erweiterte Richtlinien nutzen, klassische deaktivieren

8. Zusammenfassung

Zusammenfassung

- Erweiterte Überwachungsrichtlinien bieten feinere Kontrolle als die klassische Überwachung.
- Windows Event Forwarding sammelt Ereignisse vieler Quellsysteme zentral.
- Ein Sammler ist selbst ein kritisches, besonders zu schützendes System.
- Abonnements definieren gezielt, welche Ereignisse gesammelt werden.

9. Kontrollfragen

1. Wofür steht WEF? (leicht)
2. Welcher Befehl richtet einen Event Collector ein? (leicht)
3. Was ist ein Abonnement im WEF-Kontext? (mittel)
4. Warum sollte ein Sammler besonders geschützt werden? (mittel)
5. Ein Sammler empfängt Ereignisse von zehn Servern, aber nicht von einem elften, baugleich konfigurierten Server. Welche zwei Ursachen prüfst du zuerst? (schwer)

Lösungshinweise: 1. Windows Event Forwarding. 2. `wecutil qc`. 3. Eine Definition, welche Ereignisse von welchen Quellsystemen gesammelt werden. 4. Weil er zentral gesammelte Beweise enthält, die bei unzureichendem Schutz verfälscht oder gelöscht werden könnten. 5. Erstens, ob der elfte Server tatsächlich im Abonnement als Quellcomputer eingetragen ist; zweitens, ob die nötige Firewall-Regel für WinRM auf genau diesem Server aktiv ist.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] erweiterte Überwachungsrichtlinien per GPO aktiviert hast,
- [ ] einen Event Collector eingerichtet hast,
- [ ] ein funktionierendes Abonnement erstellt und getestet hast,
- [ ] erklären kannst, warum ein Sammler besonderen Schutz braucht.

Kapitel 15: Sicherheitsüberwachung mit Sysmon

Lernziele

- Du installierst Sysmon mit einer konfigurierten Regeldatei.
- Du findest Prozess- und Netzwerkereignisse im Sysmon-Protokoll.
- Du verbindest Sysmon mit dem Event Forwarding aus Kapitel 14.

1. Einführung

Die Standardprotokollierung aus Kapitel 14 zeigt An- und Abmeldungen. **Sysmon**, Teil der Microsoft-Sysinternals-Sammlung, protokolliert deutlich detaillierter: jeden Prozessstart, jede Netzwerkverbindung, jede Dateiänderung in überwachten Pfaden.

2. Technische Grundlagen

Sysmon läuft als Systemdienst und schreibt seine Ereignisse in ein eigenes Protokoll (`Microsoft-Windows-Sysmon/Operational`), konfiguriert über eine XML-Regeldatei, die festlegt, welche Ereignistypen in welchem Detailgrad erfasst werden.

Beispiel 15.1: Sysmon mit einer Konfigurationsdatei installieren

```
PS> .\Sysmon64.exe -accepteula -i sysmonconfig.xml
```

3. Fachbegriffe

Event-ID 1 protokolliert einen Prozessstart inklusive vollständiger Befehlszeile und Elternprozess, **Event-ID 3** eine Netzwerkverbindung, **Event-ID 11** eine Dateierstellung in einem überwachten Pfad. Eine gut gepflegte **Community-Konfiguration** (etwa die verbreitete „sysmon-modular“-Sammlung) filtert bewusst häufiges, unauffälliges Rauschen heraus.

4. Praxis und Konfiguration

Beispiel 15.2: Prozessstarts auswerten

```
PS> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" |
    Where-Object { $_.Id -eq 1 } | Select-Object -First 10 TimeCreated, Message
```

Beispiel 15.3: Sysmon-Ereignisse über WEF zentral sammeln (Ergänzung zu Kapitel 14)

```
Ereignisanzeige auf DC01 -> Abonnements -> neues Abonnement ->
Ereignisprotokoll "Microsoft-Windows-Sysmon/Operational" statt "Security"
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Eine ungefilterte Sysmon-Standardkonfiguration erzeugt sehr große Datenmengen und macht die eigentlich relevanten Ereignisse schwer auffindbar. Nutze eine kuratierte, gepflegte Konfigurationsdatei statt einer eigenen, von Grund auf neu geschriebenen.

6. Praktische Laborübungen

Übung A: Sysmon installieren und Prozessstarts beobachten

Aufgabenstellung: Installiere Sysmon auf CLIENT01 und beobachte Prozessstarts nach Ausführung eines Testprogramms. **Ausgangssituation:** CLIENT01 in der Domäne. **Voraussetzungen:** Sysmon-Installationsdatei und eine Beispielkonfiguration (z. B. von der öffentlichen sysmon-modular-Sammlung). **Schritt-für-Schritt-Anleitung:** siehe Beispiel 15.1, danach ein Testprogramm starten, dann Beispiel 15.2. **Erwartetes Ergebnis:** Ein Event-ID-1-Eintrag mit vollständiger Befehlszeile und Elternprozess des Testprogramms. **Überprüfung:** Der protokollierte Elternprozess stimmt mit dem tatsächlichen Startkontext überein (z. B. `explorer.exe` bei manuellem Doppelklick). **Fehleranalyse:** Keine Ereignisse? Dienststatus mit `Get-Service sysmon64` prüfen. **Musterlösung:** Eine dokumentierte, detaillierte Prozessstart-Protokollierung.

Übung B: Sysmon-Ereignisse zentral sammeln

Aufgabenstellung: Erweitere das Event-Forwarding-Abonnement aus Kapitel 14 um Sysmon-Ereignisse. **Ausgangssituation:** Ergebnis aus Übung A sowie Kapitel 14. **Voraussetzungen:** wie Übung A, WEF bereits eingerichtet. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 15.3. **Erwartetes Ergebnis:** Sysmon-Ereignisse von CLIENT01 erscheinen zentral auf DC01. **Überprüfung:** Ein auf CLIENT01 ausgelöstes Testereignis erscheint zeitnah auf DC01. **Fehleranalyse:** Kein Eingang? Prüfen, ob das korrekte Protokoll (Sysmon statt Security) im Abonnement ausgewählt wurde. **Musterlösung:** Eine zentral gesammelte, detaillierte Prozess- und Netzwerkprotokollierung.

7. Typische Fehler

Fehler	Ursache	Behebung
Eigene, ungefilterte Konfiguration verwendet	Standardkonfiguration ungeprüft übernommen	kuratierte, gepflegte Community-Konfiguration nutzen
Sysmon-Protokoll nie ausgewertet	fehlende Routine oder fehlendes Werkzeug	zentrale Sammlung und regelmäßige Auswertung einplanen
Sysmon mit Standard-Windows-Protokollierung verwechselt	ähnlicher Zweck, unterschiedlicher Detailgrad	Sysmon ergänzt, ersetzt aber nicht die Standardprotokollierung

8. Zusammenfassung

Zusammenfassung

- Sysmon protokolliert Prozessstarts, Netzwerkverbindungen und Dateiereignisse deutlich detaillierter als die Standardprotokollierung.
- Eine kuratierte Konfigurationsdatei filtert unauffälliges Rauschen heraus.
- Sysmon-Ereignisse lassen sich über dasselbe Event-Forwarding wie in Kapitel 14 zentral sammeln.

- Event-ID 1, 3 und 11 gehören zu den wichtigsten Sysmon-Ereignistypen.

9. Kontrollfragen

1. Welche Sammlung gehört Sysmon an? (leicht)
2. Welche Event-ID protokolliert einen Prozessstart? (leicht)
3. Warum sollte eine kuratierte statt einer eigenen Konfigurationsdatei genutzt werden? (mittel)
4. Wie lässt sich Sysmon mit dem Event Forwarding aus Kapitel 14 verbinden? (mittel)
5. Ein Sysmon-Event-ID-1-Eintrag zeigt eine PowerShell-Befehlszeile mit ungewöhnlich langen, kodierten Parametern, gestartet von einem Office-Prozess als Elternprozess. Was fällt dir daran besonders auf? (schwer)

Lösungshinweise: 1. Microsoft Sysinternals. 2. Event-ID 1. 3. Weil eine eigene Konfiguration leicht entweder zu viel Rauschen oder zu wenig relevante Details erfasst, während kuratierte Konfigurationen bereits praxiserprobt sind. 4. Indem im WEF-Abonnement das Sysmon-Protokoll statt des Security-Protokolls als Quelle ausgewählt wird. 5. Ein Office-Prozess, der PowerShell mit kodierten Parametern startet, ist ein klassisches, in der Fachliteratur gut dokumentiertes Muster für einen Makro-basierten Angriffsversuch und verdient besondere Aufmerksamkeit.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] Sysmon mit einer kuratierten Konfiguration installiert hast,
- [ ] Prozessstarts im Sysmon-Protokoll ausgewertet hast,
- [ ] Sysmon-Ereignisse zentral über WEF gesammelt hast,
- [ ] ein verdächtiges Prozessmuster erkennen kannst.

Kapitel 16: Windows Server Hardening

Lernziele

- Du installierst einen Server im Server-Core-Modus und ordnest den Sicherheitsvorteil ein.
- Du härtest die Rollenkonfiguration eines Mitgliedsservers nach dem Minimalprinzip.
- Du prüfst SRV01 gegen eine Server-spezifische CIS-Benchmark-Empfehlung.

1. Einführung

Die vorherigen Kapitel haben einzelne Mechanismen behandelt. Dieses Kapitel bündelt sie am Beispiel von SRV01 zu einer serverspezifischen Härtung, die über die clientorientierten Maßnahmen aus Band 1 hinausgeht.

2. Technische Grundlagen

Server Core installiert Windows Server ohne grafische Oberfläche, mit deutlich reduzierter Angriffsfläche (weniger Komponenten, weniger Updates nötig) gegenüber der vollständigen „Desktop Experience“-Installation. Die Verwaltung erfolgt über PowerShell oder Remote-Verwaltungstools.

Beispiel 16.1: Installierte Rollen und Features eines Servers prüfen

```
PS> Get-WindowsFeature | Where-Object { $_.InstallState -eq "Installed" }
```

3. Fachbegriffe

Das **Minimalprinzip** (bereits aus Band 1 der Linux-Schwesterreihe bekannt) bedeutet, nur tatsächlich benötigte Rollen und Features zu installieren. Eine **Server-Core-zu-Desktop-Experience-Konvertierung** ist seit mehreren Windows-Server-Versionen nicht mehr ohne Neuinstallation möglich – die Wahl beim Einrichten sollte deshalb bewusst getroffen werden.

4. Praxis und Konfiguration

Beispiel 16.2: Nicht benötigte Features entfernen

```
PS> Uninstall-WindowsFeature -Name <Feature-Name>
```

Beispiel 16.3: Eine CIS-Server-Empfehlung manuell prüfen (Beispiel)

```
CIS-Empfehlung: "Stelle sicher, dass der Gastkonto-Status deaktiviert ist"
PS> Get-LocalUser -Name "Gast" | Select-Object Enabled
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Prüfe vor dem Entfernen eines Features sorgfältig, ob eine andere, bereits installierte Rolle davon abhängt. `Get-WindowsFeature` zeigt Abhängigkeiten an, die vor einer Entfernung berücksichtigt werden sollten.

6. Praktische Laborübungen

Übung A: Rollenkonfiguration von SRV01 dokumentieren und bereinigen

Aufgabenstellung: Dokumentiere alle installierten Rollen und Features auf SRV01 und entferne nicht benötigte. **Ausgangssituation:** SRV01 nach Standardinstallation. **Voraussetzungen:** administrative Rechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 16.1, dann für jedes nicht benötigte Feature Beispiel 16.2. **Erwartetes Ergebnis:** Eine reduzierte, vollständig begründete Rollenliste. **Überprüfung:** Jede verbleibende Rolle hat eine nachvollziehbare Begründung. **Fehleranalyse:** Entferntes Feature wird doch gebraucht? Mit `Install-WindowsFeature` erneut hinzufügen. **Musterlösung:** Eine dokumentierte, nach dem Minimalprinzip bereinigte Serverkonfiguration.

Übung B: Server-spezifische CIS-Empfehlungen prüfen

Aufgabenstellung: Prüfe SRV01 gegen drei CIS-Server-Empfehlungen, darunter Beispiel 16.3. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** Zugriff auf das CIS-Benchmark-Dokument für Windows Server. **Schritt-für-Schritt-Anleitung:** Drei Empfehlungen auswählen, jeweiligen Status auf SRV01 ermitteln und dokumentieren. **Erwartetes Ergebnis:** Für jede Empfehlung eine klare, begründete Bewertung. **Überprüfung:** Jede Bewertung bezieht sich konkret auf SRV01, nicht allgemein. **Fehleranalyse:** Unklare Empfehlung? Zusätzliche Erläuterung im Benchmark-Dokument konsultieren. **Musterlösung:** Drei vollständig dokumentierte, bewertete Prüfpunkte.

7. Typische Fehler

Fehler	Ursache	Behebung
Feature ohne Abhängigkeitsprüfung entfernt	`Get-WindowsFeature`-Hinweis übersehen	Abhängigkeiten vor jeder Entfernung konsultieren
Server-Core nachträglich gewünscht	Installationsart nicht vorab bedacht	Entscheidung bewusst vor der Installation treffen
CIS-Prüfung nur einmalig durchgeführt	fehlendes Prozessverständnis	wiederkehrende Prüfungen einplanen (vergleiche Kapitel 1)

8. Zusammenfassung

Zusammenfassung

- Server Core reduziert die Angriffsfläche gegenüber der vollständigen Desktop-Experience-Installation.
- Nicht benötigte Rollen und Features sollten nach dem Minimalprinzip entfernt werden.
- Abhängigkeiten zwischen Features müssen vor einer Entfernung geprüft werden.
- CIS-Server-Benchmarks bieten konkrete, prüfbare Einzelempfehlungen.

9. Kontrollfragen

1. Was ist Server Core? (leicht)

2. Welcher Befehl listet installierte Rollen und Features? (leicht)
3. Warum ist die Entscheidung für oder gegen Server Core vor der Installation zu treffen? (mittel)
4. Was sollte vor dem Entfernen eines Features geprüft werden? (mittel)
5. Ein Server läuft seit Jahren mit der vollständigen Desktop-Experience, obwohl keine grafischen Anwendungen genutzt werden. Lohnt sich eine nachträgliche Umstellung, und was ist dabei zu beachten? (schwer)

Lösungshinweise: 1. Eine Windows-Server-Installation ohne grafische Oberfläche, mit reduzierter Angriffsfläche. 2. `Get-WindowsFeature`. 3. Weil eine Umstellung zwischen beiden Installationsarten ohne Neuinstallation nicht ohne Weiteres möglich ist. 4. Ob andere, bereits installierte Rollen von diesem Feature abhängen. 5. Eine Umstellung würde die Angriffsfläche spürbar reduzieren, erfordert aber in der Regel eine Neuinstallation; dafür sollte ein Wartungsfenster und eine vollständige Übertragung der Serverrolle auf eine neu aufgesetzte Server-Core-Installation eingeplant werden.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] die Rollenkonfiguration von SRV01 dokumentiert und bereinigt hast,
- [ ] mindestens drei CIS-Server-Empfehlungen geprüft hast,
- [ ] den Sicherheitsvorteil von Server Core erklären kannst,
- [ ] Abhängigkeiten vor dem Entfernen eines Features prüfen kannst.

Kapitel 17: Remote Administration und RDP-Sicherheit

Lernziele

- Du härtest RDP-Zugriff mit Network Level Authentication.
- Du beschränkst RDP-Zugriff auf eine definierte Gruppe statt aller Administratoren.
- Du richtest einen Jump-Host-Ansatz für administrativen Fernzugriff ein.

1. Einführung

Remote Desktop Protocol (RDP) ist einer der am häufigsten aus dem Internet erreichbaren und zugleich am häufigsten angegriffenen Windows-Dienste. Dieses Kapitel härtet ihn gezielt, ergänzend zu PowerShell Remoting (Kapitel 3).

2. Technische Grundlagen

Network Level Authentication (NLA) verlangt die Authentifizierung bereits vor dem Aufbau der vollständigen RDP-Sitzung, statt erst nach dem Laden des Anmeldebildschirms – das reduziert die Angriffsfläche gegenüber nicht authentifizierten Verbindungsversuchen erheblich.

Beispiel 17.1: NLA-Status prüfen

```
PS> Get-CimInstance -ClassName Win32_TSGeneralSetting `
    -Namespace root\cimv2\terminalservices | Select-Object UserAuthenticationRequired
```

3. Fachbegriffe

Ein **Jump Host** (Bastion Host) ist ein eigens gehärtetes System, über das sämtlicher administrativer Fernzugriff geleitet wird, statt jeden Server einzeln direkt per RDP erreichbar zu machen. **Remote Desktop Gateway** erlaubt RDP-Zugriff verschlüsselt über HTTPS, ohne Port 3389 direkt exponieren zu müssen.

4. Praxis und Konfiguration

Beispiel 17.2: NLA per GPO erzwingen

```
Computerkonfiguration -> Richtlinien -> Administrative Vorlagen -> Windows-Komponenten ->
Remotedesktopdienste -> Remotedesktop-Sitzungshost -> Sicherheit ->
"Authentifizierung auf Netzwerkebene erforderlich" -> Aktiviert
```

Beispiel 17.3: RDP-Zugriff auf eine definierte Gruppe beschränken

```
PS> Restrict-RdsAccess -Group "nova\RDP-Berechtigt" -ComputerName SRV01
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

RDP sollte niemals direkt aus dem öffentlichen Internet erreichbar sein. Nutze stattdessen ein VPN, ein Remote Desktop Gateway oder einen Jump Host als kontrollierten Zwischenpunkt.

6. Praktische Laborübungen

Übung A: NLA erzwingen und testen

Aufgabenstellung: Erzwinge NLA per GPO und bestätige die Wirkung. **Ausgangssituation:** SRV01 mit aktiviertem RDP. **Voraussetzungen:** administrative Domänenrechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 17.1, 17.2. **Erwartetes Ergebnis:** `UserAuthenticationRequired` zeigt `1` nach der Änderung. **Überprüfung:** Ein RDP-Client ohne NLA-Unterstützung kann sich nicht mehr verbinden. **Fehleranalyse:** Keine Änderung sichtbar? `gpupdate /force` auf SRV01 ausführen. **Musterlösung:** Eine bestätigte, erzwungene NLA-Konfiguration.

Übung B: RDP-Zugriff auf eine Gruppe beschränken

Aufgabenstellung: Beschränke RDP-Zugriff auf SRV01 auf eine eigens angelegte Gruppe. **Ausgangssituation:** Ergebnis aus Übung A, Gruppe „RDP-Berechtigt“ mit einem Testmitglied angelegt. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 17.3, danach Verbindungsversuch mit einem Konto außerhalb der Gruppe testen. **Erwartetes Ergebnis:** Nur Mitglieder der Gruppe können sich per RDP verbinden. **Überprüfung:** Ein nicht berechtigtes Konto erhält eine klare Zugriffsverweigerung. **Fehleranalyse:** Zugriff trotzdem erlaubt? Lokale Gruppe „Remotedesktopbenutzer“ auf SRV01 zusätzlich prüfen. **Musterlösung:** Ein nachweislich auf die definierte Gruppe beschränkter RDP-Zugriff.

7. Typische Fehler

Fehler	Ursache	Behebung
RDP direkt aus dem Internet erreichbar	fehlende Netzwerksegmentierung	Jump Host, VPN oder RD Gateway zwischenschalten
NLA deaktiviert wegen älterer Clients	Kompatibilität über Sicherheit gestellt	Clients aktualisieren statt NLA zu deaktivieren
Lokale Gruppe „Remotedesktopbenutzer“ zu breit besetzt	zusätzlich zur zentralen Beschränkung nicht geprüft	beide Ebenen (lokal und zentral) konsistent halten

8. Zusammenfassung

Zusammenfassung

- NLA verlangt Authentifizierung vor dem vollständigen Sitzungsaufbau und reduziert die Angriffsfläche erheblich.
- RDP-Zugriff sollte auf eine definierte Gruppe statt pauschal alle Administratoren beschränkt werden.
- Ein Jump Host oder Remote Desktop Gateway verhindert direkte Erreichbarkeit aus dem Internet.
- Lokale und zentrale Zugriffsbeschränkungen müssen konsistent gehalten werden.

9. Kontrollfragen

1. Wofür steht NLA? (leicht)
2. Was ist ein Jump Host? (leicht)
3. Warum reduziert NLA die Angriffsfläche gegenüber klassischem RDP? (mittel)
4. Welche zwei Ebenen der RDP-Zugriffsbeschränkung sollten konsistent gehalten werden? (mittel)
5. Ein Unternehmen exponiert Port 3389 direkt im Internet, „weil Mitarbeitende von unterwegs zugreifen müssen“. Welche sicherere Alternative schlägst du vor? (schwer)

Lösungshinweise: 1. Network Level Authentication. 2. Ein eigens gehärtetes System, über das sämtlicher administrativer Fernzugriff geleitet wird. 3. Weil die Authentifizierung bereits vor dem vollständigen Sitzungsaufbau erfolgt, statt erst danach. 4. Die zentrale Gruppenbeschränkung (Beispiel 17.3) und die lokale Gruppe „Remotedesktopbenutzer“ auf dem Zielserver. 5. Ein VPN oder ein Remote Desktop Gateway einrichten, über das RDP-Zugriff verschlüsselt und authentifiziert erfolgt, statt Port 3389 direkt im Internet zu exponieren.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] NLA per GPO erzwungen und getestet hast,
- [ ] RDP-Zugriff auf eine definierte Gruppe beschränkt hast,
- [ ] erklären kannst, warum RDP nie direkt im Internet exponiert werden sollte,
- [ ] eine sichere Alternative für mobilen administrativen Zugriff nennen kannst.

Kapitel 18: Backup- und Wiederherstellungskonzepte

Lernziele

- Du sicherst Active Directory mit Windows Server Backup.
- Du führst eine autoritative Wiederherstellung eines gelöschten AD-Objekts durch.
- Du wendest die 3-2-1-Regel auf eine Domänenumgebung an.

1. Einführung

Jede bisherige Härtungsmaßnahme kann versagen. Ein funktionierendes Backup ist die letzte Verteidigungslinie – unter Active Directory mit einer Besonderheit: Ein gelöschtes AD-Objekt lässt sich nicht einfach wie eine Datei zurückkopieren.

2. Technische Grundlagen

Windows Server Backup sichert einen Domain Controller vollständig, einschließlich der **Active-Directory-Datenbank** (NTDS.dit). Eine **autoritative Wiederherstellung** markiert ein wiederhergestelltes Objekt ausdrücklich als neueren Stand, damit es sich nach der Wiederherstellung zu den übrigen Domain Controllern repliziert, statt von ihnen überschrieben zu werden.

Beispiel 18.1: Windows Server Backup installieren und ein Systemstatus-Backup erstellen

```
PS> Install-WindowsFeature Windows-Server-Backup
PS> wbadmin start systemstatebackup -backuptarget:D:
```

3. Fachbegriffe

Der **Active Directory Recycle Bin** erlaubt, kürzlich gelöschte Objekte innerhalb einer bestimmten Frist ohne vollständige Systemwiederherstellung zurückzuholen, sofern er vorab aktiviert wurde. Der **Tombstone Lifetime** bestimmt, wie lange gelöschte Objekte überhaupt noch in einem wiederherstellbaren Zustand vorliegen.

4. Praxis und Konfiguration

Beispiel 18.2: Active Directory Recycle Bin aktivieren

```
PS> Enable-ADOptionalFeature -Identity "Recycle Bin Feature" `
    -Scope ForestOrConfigurationSet -Target "nova.int"
```

Beispiel 18.3: Ein gelöschtes Objekt aus dem Recycle Bin wiederherstellen

```
PS> Get-ADObject -Filter {displayName -eq "Test Benutzer"} -IncludeDeletedObjects |
    Restore-ADObject
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Aktiviere den Active Directory Recycle Bin frühzeitig, idealerweise direkt nach der Ersteinrichtung der Domäne. Er lässt sich zwar jederzeit aktivieren, schützt aber nur Objekte, die nach der Aktivierung gelöscht werden, nicht rückwirkend.

6. Praktische Laborübungen

Übung A: AD Recycle Bin aktivieren und testen

Aufgabenstellung: Aktiviere den Recycle Bin, lösche ein Testobjekt, und stelle es wieder her. **Ausgangssituation:** DC01, Recycle Bin noch nicht aktiviert. **Voraussetzungen:** administrative Domänenrechte (Schema-Admin-Rechte für die Aktivierung). **Schritt-für-Schritt-Anleitung:** siehe Beispiel 18.2, dann ein Testkonto löschen, dann Beispiel 18.3. **Erwartetes Ergebnis:** Das gelöschte Testkonto erscheint nach der Wiederherstellung wieder vollständig, inklusive Gruppenmitgliedschaften. **Überprüfung:** `Get-ADUser` findet das wiederhergestellte Konto wieder. **Fehleranalyse:** Wiederherstellung schlägt fehl? Prüfen, ob der Recycle Bin tatsächlich vor der Löschung aktiviert war. **Musterlösung:** Ein vollständig wiederhergestelltes Testkonto mit allen ursprünglichen Attributen.

Übung B: Systemstatus-Backup erstellen und Konzept dokumentieren

Aufgabenstellung: Erstelle ein Systemstatus-Backup von DC01 und dokumentiere ein vollständiges Backup-Konzept nach der 3-2-1-Regel für die Domäne. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** ausreichend Speicherplatz für das Backup-Ziel. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 18.1, danach ein Konzept mit mindestens drei Kopien, zwei Medientypen und einem externen Standort für die Domänendaten entwerfen. **Erwartetes Ergebnis:** Ein erfolgreiches Backup sowie ein vollständiges, dokumentiertes Konzept. **Überprüfung:** Das Konzept benennt konkret, wo die drei Kopien liegen und auf welchen Medientypen. **Fehleranalyse:** Backup schlägt fehl? Freien Speicherplatz auf dem Zielvolume prüfen. **Musterlösung:** Ein erfolgreiches Backup und ein vollständiges 3-2-1-Konzept für die Domäne.

7. Typische Fehler

Fehler	Ursache	Behebung
Recycle Bin erst nach einem Vorfall aktiviert	fehlende Weitsicht	frühzeitig, direkt nach Ersteinrichtung aktivieren
Nur ein Domain Controller gesichert	Annahme, ein DC genüge für die ganze Domäne	jeden Domain Controller eigenständig sichern
Backup nie getestet	Vertrauen ohne Überprüfung	regelmäßige Testwiederherstellungen einplanen

8. Zusammenfassung

Zusammenfassung

- Windows Server Backup sichert einen Domain Controller inklusive Active-Directory-Datenbank.

- Der AD Recycle Bin erlaubt einfache Wiederherstellung kürzlich gelöschter Objekte, aber nur rückwirkend ab seiner Aktivierung.
- Eine autoritative Wiederherstellung verhindert, dass ein wiederhergestelltes Objekt von anderen Domain Controllern überschrieben wird.
- Die 3-2-1-Regel gilt für Domänendaten genauso wie für jedes andere System.

9. Kontrollfragen

1. Was sichert ein Systemstatus-Backup eines Domain Controllers? (leicht)
2. Welcher Befehl aktiviert den AD Recycle Bin? (leicht)
3. Warum schützt der Recycle Bin nicht rückwirkend? (mittel)
4. Was bewirkt eine autoritative Wiederherstellung? (mittel)
5. Eine Domäne mit drei Domain Controllern sichert nur einen davon regelmäßig. Welches konkrete Risiko ergibt sich daraus, auch wenn die beiden anderen DCs weiterlaufen? (schwer)

Lösungshinweise: 1. Die Active-Directory-Datenbank (NTDS.dit) und weitere systemkritische Komponenten. 2. `Enable-ADOptionalFeature -Identity "Recycle Bin Feature"`. 3. Weil er nur Objekte schützt, die nach seiner Aktivierung gelöscht werden, nicht bereits zuvor gelöschte. 4. Sie markiert ein wiederhergestelltes Objekt als neueren Stand, damit es sich zu den übrigen Domain Controllern repliziert statt überschrieben zu werden. 5. Fällt der gesicherte Domain Controller mit einem schwerwiegenden, ungesicherten Datenverlust aus, gibt es keine eigenständige, vollständige Wiederherstellungsgrundlage mehr für genau diesen DC, selbst wenn die Domäne über die anderen DCs weiterläuft.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] den AD Recycle Bin aktiviert und eine Wiederherstellung durchgeführt hast,
- [ ] ein Systemstatus-Backup erstellt hast,
- [ ] ein vollständiges 3-2-1-Konzept für eine Domäne dokumentiert hast,
- [ ] erklären kannst, warum jeder Domain Controller eigenständig gesichert werden sollte.

Kapitel 19: Sicherheitskonzepte für Unternehmensnetzwerke

Lernziele

- Du verbindest die Maßnahmen aus Kapitel 1-18 zu einem zusammenhängenden Sicherheitskonzept.
- Du erstellst eine Risikobewertung für die Domänenumgebung.
- Du dokumentierst ein vollständiges Hardening-Konzept nach einheitlichem Schema.

1. Einführung

Die vorherigen achtzehn Kapitel haben Einzelmaßnahmen behandelt. Ein Unternehmensnetzwerk braucht mehr: ein zusammenhängendes Konzept, das begründet, welche Maßnahmen warum in welcher Priorität umgesetzt werden.

2. Technische Grundlagen

Ein **Sicherheitskonzept** verbindet Bestandsaufnahme, Risikobewertung, konkrete Maßnahmen und deren Dokumentation zu einem nachvollziehbaren Gesamtbild – dasselbe Grundprinzip wie in der Linux-Schwesterreihe, hier auf eine Active-Directory-Umgebung angewendet.

Beispiel 19.1: Eine einfache Risikomatrix (Konzept)

```
                geringe Auswirkung    hohe Auswirkung
hohe W'keit     mittlere Priorität    höchste Priorität
geringe W'keit  niedrigste Priorität  mittlere Priorität
```

3. Fachbegriffe

Der **Schutzbedarf** beschreibt, wie kritisch Vertraulichkeit, Integrität und Verfügbarkeit eines Systems für die Organisation sind – ein Domain Controller hat typischerweise den höchsten Schutzbedarf im gesamten Netzwerk, da seine Kompromittierung praktisch jedes andere System gefährdet.

4. Praxis und Konfiguration

Beispiel 19.2: Struktur eines Sicherheitskonzepts (Gliederungsvorschlag)

```
1. Zweck und Schutzbedarf der Umgebung
2. Bestandsaufnahme (Systeme, Rollen, Trust-Beziehungen)
3. Risikobewertung je identifizierter Bedrohung
4. Umgesetzte Maßnahmen, Kapitel für Kapitel zugeordnet
5. Verbleibende, bewusst akzeptierte Restrisiken
6. Verantwortlichkeiten und Aktualisierungsturnus
```

Beispiel 19.3: Eine Maßnahme einer Bedrohung zuordnen (Auszug)

```
Bedrohung: Kompromittierung eines Domain Admin-Kontos
Maßnahme:  minimale Gruppenbesetzung (Kap. 5), Delegation statt voller Rechte,
           Fine-Grained Password Policy (Kap. 6), zentrale Protokollierung (Kap. 14)
Priorität: höchste (geringe Wahrscheinlichkeit bei guter Härtung, sehr hohe Auswirkung)
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Ein Domain Controller verdient in jeder Risikobewertung die höchste Priorität: Seine Kompromittierung bedeutet praktisch immer die Kompromittierung der gesamten Domäne, unabhängig davon, wie gut einzelne Clients gehärtet sind.

6. Praktische Laborübungen

Übung A: Ein Sicherheitskonzept für die gesamte Domäne erstellen

Aufgabenstellung: Erstelle ein vollständiges, schriftliches Sicherheitskonzept für DC01, SRV01 und CLIENT01 nach der Gliederung aus Beispiel 19.2. **Ausgangssituation:** Alle vorherigen 18 Kapitel dieses Bandes abgeschlossen. **Voraussetzungen:** Zugriff auf alle bisherigen Übungsdokumentationen dieses Bandes. **Schritt-für-Schritt-Anleitung:** Gliederung übernehmen, jeden Abschnitt mit den tatsächlichen Gegebenheiten der Domäne füllen. **Erwartetes Ergebnis:** Ein zusammenhängendes Dokument von der Zweckbestimmung bis zu Verantwortlichkeiten. **Überprüfung:** Jede in den Kapiteln 1-18 umgesetzte Maßnahme taucht im Konzept mit Zuordnung zu einer konkreten Bedrohung auf. **Fehleranalyse:** Lücken im Konzept? Mit der Kapitelübersicht aus dem Vorwort abgleichen. **Musterlösung:** Ein vollständiges Konzept, das alle neunzehn Kapitel zu einer in sich stimmigen Dokumentation verbindet.

Übung B: Eine Risikobewertung mit Priorisierung durchführen

Aufgabenstellung: Identifiziere fünf konkrete Bedrohungen für die Domäne und ordne sie nach der Risikomatrix aus Beispiel 19.1 ein. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** keine zusätzlichen. **Schritt-für-Schritt-Anleitung:** Fünf Bedrohungen benennen (z. B. Domain-Admin-Kompromittierung, NTLM-Relay, fehlende Backups, ungehärteter Server, fehlende Protokollauswertung), jeweils einschätzen und priorisieren. **Erwartetes Ergebnis:** Eine nach Priorität sortierte Liste mit zugeordneter Gegenmaßnahme aus den vorherigen Kapiteln. **Überprüfung:** Die höchste Priorität entspricht der am schwersten wiegenden, wahrscheinlichsten Bedrohung. **Fehleranalyse:** Einschätzungen wirken willkürlich? Mit einer zweiten Person gegenprüfen. **Musterlösung:** Eine vollständige, begründete Priorisierung mit Gegenmaßnahmen.

7. Typische Fehler

Fehler	Ursache	Behebung
Konzept nur für Clients, nicht für die Domäneninfrastruktur erstellt	Domain Controller und Server übersehen	alle drei Systemtypen gleichwertig einbeziehen
Alle Risiken gleich priorisiert	fehlende systematische Bewertung	Risikomatrix konsequent anwenden
Domain Controller nicht als höchste Priorität erkannt	Bedeutung der zentralen Rolle unterschätzt	AD-Kompromittierung immer als Extremrisiko behandeln

8. Zusammenfassung

Zusammenfassung

- Ein Sicherheitskonzept verbindet Bestandsaufnahme, Risikobewertung, Maßnahmen und Dokumentation.
- Ein Domain Controller hat in jeder Domäne den höchsten Schutzbedarf.
- Eine Risikomatrix hilft, Maßnahmen nach Wahrscheinlichkeit und Auswirkung zu priorisieren.
- Restrisiken sollten bewusst dokumentiert, nicht stillschweigend übersehen werden.

9. Kontrollfragen

1. Was gehört in die Gliederung eines vollständigen Sicherheitskonzepts? (leicht)
2. Warum hat ein Domain Controller den höchsten Schutzbedarf in einer Domäne? (leicht)
3. Was ist ein Restrisiko? (mittel)
4. Wonach priorisiert eine Risikomatrix Bedrohungen? (mittel)
5. Zwei Unternehmen haben identische technische AD-Konfiguration, eines mit zehn, eines mit zehntausend Benutzerkonten. Sollte ihr Sicherheitskonzept identisch sein? (schwer)

Lösungshinweise: 1. Zweck, Bestandsaufnahme, Risikobewertung, Maßnahmen, Restrisiken, Verantwortlichkeiten. 2. Weil seine Kompromittierung praktisch jedes andere System in der Domäne gefährdet. 3. Ein nicht vollständig behobenes, aber bewusst akzeptiertes Risiko. 4. Nach Eintrittswahrscheinlichkeit und Schwere der Auswirkung. 5. Nein, die unterschiedliche Größe verändert Angriffsfläche und Auswirkung erheblich (z. B. mehr potenzielle Phishing-Ziele, komplexere Delegationsstrukturen), was unterschiedliche Prioritäten und Kontrollintensität rechtfertigt, selbst bei identischer Grundkonfiguration.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] ein vollständiges Sicherheitskonzept für die Domäne erstellt hast,
- [ ] eine Risikobewertung mit Priorisierung durchgeführt hast,
- [ ] erklären kannst, warum ein Domain Controller besondere Priorität verdient,
- [ ] erklären kannst, warum identische Technik unterschiedliche Konzepte rechtfertigen kann.

Abschlussprojekt Band 2: Sicheres Unternehmensnetzwerk

Richte eine vollständige, gehärtete Active-Directory-Infrastruktur ein, die alle neunzehn Kapitel dieses Bandes zusammenführt:

1. **Active Directory:** Domäne nova.int eingerichtet, Recycle Bin aktiviert (Kapitel 18).
2. **Benutzer- und Gruppenstruktur:** minimal besetzte privilegierte Gruppen, Delegation statt voller Rechte, Fine-Grained Password Policy für Administratoren (Kapitel 5-6).
3. **Gruppenrichtlinien:** mindestens eine Security Baseline importiert, eigene Härtungs-GPOs für Firewall und Defender (Kapitel 2, 9-10).
4. **Protokollierung:** zentrales Event Forwarding mit Sysmon-Ergänzung (Kapitel 14-15).
5. **Serverhärtung:** SRV01 nach Minimalprinzip bereinigt, RDP-Zugriff beschränkt (Kapitel 16-17).
6. **Backup:** Systemstatus-Backup von DC01, dokumentiertes 3-2-1-Konzept (Kapitel 18).

7. **Sicherheitsbericht:** ein vollständiges Sicherheitskonzept nach dem Schema aus Kapitel 19, das alle umgesetzten Maßnahmen begründet zusammenfasst.

Dieses Projekt bildet die Grundlage für Band 3, in dem dieselbe, nun gehärtete Domäne aus Angreiferperspektive analysiert wird.

Verzeichnis der Befehlsbeispiele

Beispiel V.1: Erweiterte Netzwerkarchitektur … Seite 9
Beispiel V.2: Active Directory Domain Services installieren … Seite 9
Beispiel V.3: SRV01 und CLIENT01 der Domäne beitreten lassen … Seite 9
Beispiel 1.1: Der Hardening-Kreislauf (Konzept) … Seite 11
Beispiel 1.2: Eine einfache Baseline-Dokumentation beginnen … Seite 11
Beispiel 2.1: Baseline-GPOs mit LGPO.exe importieren (Konzept) … Seite 14
Beispiel 2.2: Eine Baseline als Domänen-GPO importieren … Seite 14
Beispiel 2.3: Aktuelle Richtlinieneinstellungen eines Systems exportieren (Vergleichsgrundlage) … Seite 14
Beispiel 3.1: Einen Befehl auf mehreren Systemen gleichzeitig ausführen … Seite 17
Beispiel 3.2: Ein einfaches Sicherheitsprüfskript für mehrere Systeme … Seite 17
Beispiel 3.3: Einen Constrained Endpoint registrieren (Konzept) … Seite 17
Beispiel 4.1: Verarbeitungsreihenfolge (Konzept) … Seite 20
Beispiel 4.2: Eine neue Organisationseinheit und ein GPO anlegen … Seite 20
Beispiel 4.3: Eine konkrete Einstellung im GPO setzen … Seite 20
Beispiel 4.4: Wirksamkeit prüfen … Seite 21
Beispiel 5.1: Mitglieder privilegierter Gruppen anzeigen … Seite 23
Beispiel 5.2: Delegation für Passwort-Reset einrichten … Seite 23
Beispiel 5.3: Mitgliedschaft in Domain Admins minimal halten … Seite 23
Beispiel 6.1: Domänenbenutzer und -gruppe anlegen … Seite 26
Beispiel 6.2: Eine strengere Passwort-Richtlinie für eine Gruppe einrichten … Seite 26
Beispiel 7.1: Kerberos-Ablauf (stark vereinfacht) … Seite 29
Beispiel 7.2: NTLM-Nutzung im Netzwerk protokollieren (vor Einschränkung) … Seite 29
Beispiel 7.3: NTLM-Ereignisse im Protokoll einsehen … Seite 29
Befehl zu Übung B … Seite 30
Beispiel 8.1: SMB-Protokollversionen prüfen … Seite 32
Beispiel 8.2: SMBv1 deaktivieren … Seite 32
Beispiel 8.3: SMB-Signierung erzwingen (per GPO) … Seite 32
Beispiel 8.4: Eine Freigabe mit angemessenen Berechtigungen einrichten … Seite 32
Beispiel 9.1: Firewall-Regel als GPO-Element definieren … Seite 35
Beispiel 9.2: Firewall-Status aller Domänenmitglieder zentral prüfen … Seite 35
Beispiel 9.3: Firewall-Protokollierung aktivieren … Seite 35
Beispiel 10.1: Defender-Konfiguration zentral per GPO (Konzept) … Seite 38
Beispiel 10.2: Eine ASR-Regel im Testmodus aktivieren … Seite 38
Beispiel 10.3: ASR-Ereignisse auswerten … Seite 38
Beispiel 11.1: Wiederherstellungsschlüssel aus Active Directory abrufen … Seite 41
Beispiel 11.2: BitLocker-Speicherung in AD per GPO erzwingen … Seite 41
Beispiel 11.3: BitLocker Recovery Password Viewer auf DC01 installieren … Seite 41
Beispiel 12.1: Unnötige Dienste auf SRV01 identifizieren … Seite 44
Beispiel 12.2: Einen gMSA erstellen und einem Dienst zuweisen … Seite 44
Beispiel 12.3: Einem Dienst das gMSA zuweisen (Dienste-Snap-In oder PowerShell) … Seite 44
Beispiel 13.1: AppLocker-Regeln auf Basis vorhandener Software automatisch generieren … Seite 47
Beispiel 13.2: Den AppLocker-Dienst aktivieren und Regeln im Audit-Modus testen … Seite 47
Beispiel 13.3: AppLocker-Ereignisse auswerten … Seite 47
Beispiel 14.1: Erweiterte Überwachungsrichtlinie per GPO aktivieren … Seite 50
Beispiel 14.2: Windows Event Collector auf DC01 einrichten … Seite 50
Beispiel 14.3: Ein Abonnement für fehlgeschlagene Anmeldungen erstellen (Konzept) … Seite 50
Beispiel 14.4: Eine Aufgabe erstellen, die auf ein Ereignis reagiert … Seite 50
Beispiel 15.1: Sysmon mit einer Konfigurationsdatei installieren … Seite 53
Beispiel 15.2: Prozessstarts auswerten … Seite 53
Beispiel 15.3: Sysmon-Ereignisse über WEF zentral sammeln (Ergänzung zu Kapitel 14) … Seite 53
Beispiel 16.1: Installierte Rollen und Features eines Servers prüfen … Seite 56
Beispiel 16.2: Nicht benötigte Features entfernen … Seite 56

Beispiel 16.3: Eine CIS-Server-Empfehlung manuell prüfen (Beispiel) … Seite 56
Beispiel 17.1: NLA-Status prüfen … Seite 59
Beispiel 17.2: NLA per GPO erzwingen … Seite 59
Beispiel 17.3: RDP-Zugriff auf eine definierte Gruppe beschränken … Seite 59
Beispiel 18.1: Windows Server Backup installieren und ein Systemstatus-Backup erstellen … Seite 62
Beispiel 18.2: Active Directory Recycle Bin aktivieren … Seite 62
Beispiel 18.3: Ein gelöschtes Objekt aus dem Recycle Bin wiederherstellen … Seite 62
Beispiel 19.1: Eine einfache Risikomatrix (Konzept) … Seite 65
Beispiel 19.2: Struktur eines Sicherheitskonzepts (Gliederungsvorschlag) … Seite 65
Beispiel 19.3: Eine Maßnahme einer Bedrohung zuordnen (Auszug) … Seite 65

Index

Active Directory – 9, 11, 15, 21, 23, 26, 29, 41
AppLocker – 47, 48, 49
ASR – 38, 39, 40
Baseline – 11, 12, 13, 14, 15, 16, 20, 67
BitLocker – 9, 41, 42, 43
Delegation – 23, 24, 25, 67
Domain Admins – 23, 24, 25
Event Forwarding – 50, 51, 52, 55, 67
gMSA – 44, 45, 46
GPO – 11, 13, 14, 15, 16, 20, 21, 22
Gruppenrichtlinie – 9, 11, 14, 15, 16, 20, 22, 67
Kerberos – 29, 30, 31
NLA – 15, 59, 60, 61
NTLM – 29, 30, 31, 66
RDP – 27, 28, 53, 59, 60, 61, 67
Recycle Bin – 62, 63, 64, 67
Server Core – 56, 57, 58
SMB – 32, 33, 34, 36
Sysmon – 50, 53, 54, 55, 67
WDAC – 47, 49